

Day177 内网对抗-信息收集篇&自动项目&本机导出&外部打点&域内通讯&Pillager&BloodHound



1.知识点

- 1、基石框架篇-单域架构-权限控制-用户和网络
- 2、基石框架篇-单域架构-环境搭建-准备和加入
- 3、基石框架篇-单域架构-信息收集-手工和工具

-
- 1、基石框架篇-父域子域架构-权限控制-用户和网络
 - 2、基石框架篇-父域子域架构-环境搭建-准备和加入
 - 3、基石框架篇-父域子域架构-信息收集-手工和工具

-
- 1、基石框架篇-域树&域林架构-权限控制-用户和网络
 - 2、基石框架篇-域树&域林架构-环境搭建-准备和加入
 - 3、基石框架篇-域树&域林架构-信息收集-手工和工具

-
- 1、代理隧道篇-代理通讯网络不可达-正反向连接上线
 - 2、代理隧道篇-代理通讯网络不可达-SockS代理配置

-
- 1、代理隧道篇-单向防火墙&双向防火墙-命令关闭
 - 2、代理隧道篇-单向防火墙&双向防火墙-正向反向
 - 3、代理隧道篇-单向防火墙&双向防火墙-隧道技术

-
- 1、隧道技术篇-网络层-ICMP协议-判断&封装&建立&穿透
 - 2、隧道技术篇-传输层-DNS协议-判断&封装&建立&穿透
 - 3、隧道技术篇-表示层-SMB协议-判断&封装&建立&穿透

-
- 1、C2/C2上线-CrossC2插件-多系统平台支持
 - 2、隧道技术篇-应用层-SSH协议-判断&封装&建立&穿透
 - 3、隧道技术篇-应用层-HTTP协议-判断&封装&建立&穿透

-
- 1、隧道技术篇-传输层-工具项目-Frp&Nps&Chisel
 - 2、隧道技术篇-传输层-端口转发&Socks建立&C2上线

-
- 1、信息收集篇-网络架构-出网&角色&服务&成员
 - 2、信息收集篇-安全防护-杀毒&防火墙&流量监控
 - 3、信息收集篇-密码凭据-系统&工具&网站&网络

- 1、信息收集篇-自动化工具项目-本机敏感信息
- 2、信息收集篇-自动化工具项目-综合打点信息
- 3、信息收集篇-自动化工具项目-域内分析信息

2.详细点



- 1 1、认知处于什么网络环境下
- 2 2、认知内网域分类及成员架构
- 3 3、认知信息收集有那些重要信息
- 4 4、认知代理隧道有那些方法技术
- 5 5、认知横向移动有那些方法技术
- 6 5、认知权限维持有那些方法技术

2.1 工作组



- 1 将不同的计算机按照功能分别列入不同的工作组。想要访问某个部门的资源，只要在“网络”里面双击该部门的工作组名。工作组就像一个可以自由进入和退出的社团，方便同组的计算机相互访问，工作组没有集中管理作用，工作组里的计算机都是相互对等的（即没有服务器和客户机之分）。对局域网中的计算机进行分类，使得网络更有序。计算机的管理依然是各自为政，所有计算机依然是对等的，松散会员制，可以随意加入和退出，且不同工作组之间的共享资源可以相互访问。

2.2 内网域



- 1 分类：单域、子域、父域、域树、域森林、DNS域名服务器
- 2 “域”是一个有安全边界的计算机组合（一个域中的用户无法访问另一个域中的资源），域内资源由一台域控制器（Domain Controller, DC）集中管理，用户名和密码是放在域控制器去验证的。
- 3 优点：通过组策略来统一管理。
- 4 单域：即只有一个域的网络环境，一般需要两台DC，一台DC，另一台备用DC（容灾）
- 5 父子域：类比公司总部和公司分部的关系，总部的域称为父域，各分部的域称为该域的子域。使用父子域的好处：
- 6
 - 减小了域之间信息交互的压力（域内信息交互不会压缩，域间信息交互可压缩）
 - 不同的子域可以指定特定的安全策略
- 8 父子域中域名使用一个.表示一个层次，类似于DNS域名表示方式，子域只能使用父域的名字作为域名后缀
- 9 域树：多个域通过建立信任关系组成的集合。若两个域之间需要相互访问，需要建立信任关系（Trust Relation），通过信任关系可以将父子域连接成树状结构
- 10 域森林：多个域树通过建立信任关系组成的集合。
- 11 域名服务器：实现域名到IP地址的转换。由于域中计算机使用DNS来定位DC、服务器和其他计算机的，所以域的名字就是DNS域的名字。
- 12 内网渗透中，大都是通过寻找DNS服务器来确定域控制器位置（因为DNS服务器和域控制器通常配置在一台机器上）

2.3 域内权限



- 1 • 域本地组：
- 2 • 多域用户访问单域资源
- 3 • （访问同一个域），主要用于授予本域内资源的访问权限，可以从任何域中添加用户账号、通用组和全局组。域本地组无法嵌套在其他组中
- 4 • 全局组：
- 5 • 单域用户访问多域资源
- 6 • （必须是同一个域中的用户），只能在创建该全局组的域中添加用户和全局组，但可以在域森林中的任何域内指派权限，也可以嵌套在其他组中
- 7 • 通用组：多域用户访问多域资源，成员信息不保存在域控制器中，而是保存在全局编录（GC）中，任何变化都会导致全林复制

2.4 域内组划分



- 1 域本地组：来自全林作用于本域
- 2 全局组：来自本域作用于全林
- 3 通用组：来自全林作用于全林
- 4 本地域组的权限
- 5 Administrators（管理员组） ----最重要的权限
- 6 Remote Desktop Users（远程登录组）
- 7 Print Operators（打印机操作员组）
- 8 Account Operators（帐号操作员组）
- 9 Server Operators（服务器操作员组）
- 10 Backup Operators（备份操作员组）
- 11 全局组、通用组的权限
- 12 Domain Admins（域管理员组） ----最最最重要的权限，一般来说域渗透是看重这个
- 13 Enterprise Admins（企业系统管理员组） ----最重要的权限，其次是去看重这个权限
- 14 Schema Admins（架构管理员组） ----最重要的权限
- 15 Domain Users（域用户组）

2.5 A-G-DL-P策略



- 1 A 代表用户账号（Account）。
- 2 G 代表全局组（Global Group）。
- 3 DL 代表域本地组（Domain Local Group）。
- 4 P 代表资源访问权限（Permission）。
- 5 A-G-DL-P策略是一种将用户账号添加到全局组中，然后将全局组添加到域本地组中，并为域本地组分配资源访问权限的策略。这种策略使得来自不同域的用户能够通过全局组和域本地组的组织方式，访问本地域中的资源。

2.6 域环境应用

1

- 账号集中管理

2

- 软件集中管理

3

- 环境集中管理

4

- 增强统一安全性

2.7 域环境架构

1

域控制器

2

成员服务器

3

客户机

4

独立服务器

5

见图：（单域，父域，子域，域树，域森林）

6

单域是指网络环境中只有一个域，建立一个单独的域足以。

7

父子域在一个域中划分出多个域，被划分的域为父域，划分出来的域为子域。

8

域树中的命名空间具有连续性，并且域名层次越深，级别越低。

9

域林是指一个或多个没有形成连续名字空间的域树组成的域树集合。

3.演示案例

3.1 信息收集-工具项目-本机凭据收集类-Searchall&Pillager

3.1.1 HackBrowserData

1

1、HackBrowserData 快速获取浏览器的账户密码

2

<https://github.com/moonD4rk/HackBrowserData>

1

hack-browser-data.exe -h

2

hack-browser-data.exe -b all -f json --dir results --zip

3

hack-browser-data.exe -b chrome -p "E:\工具\信息收集工具\hack-browser-data--快速获取浏览器的账户密码\data"

```
C:\Windows\System32\cmd.exe
E:\工具\信息收集工具\hack-browser-data--快速获取浏览器的账户密码>hack.exe -h
NAME:
  hack-browser-data - Export passwords|bookmarks|cookies|history|credit cards|download history|localStorage|extensions from browser

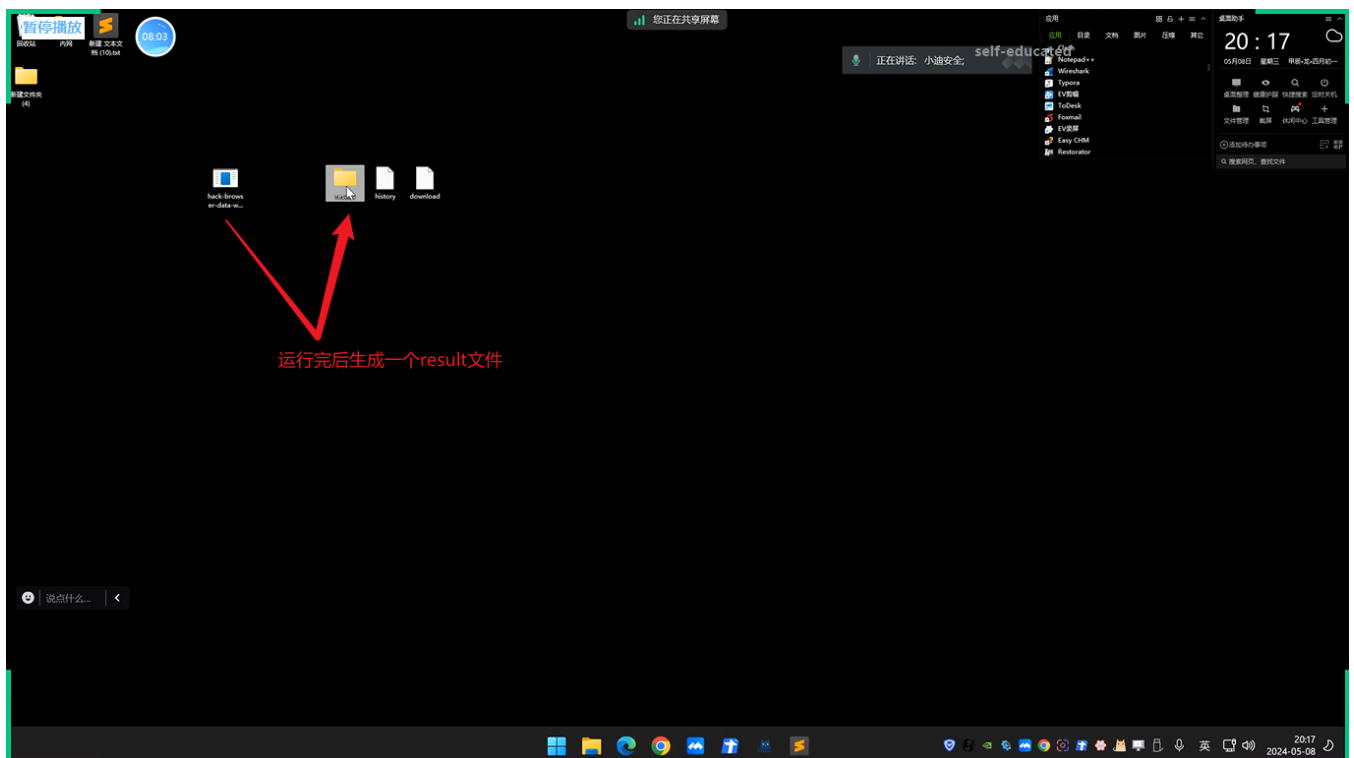
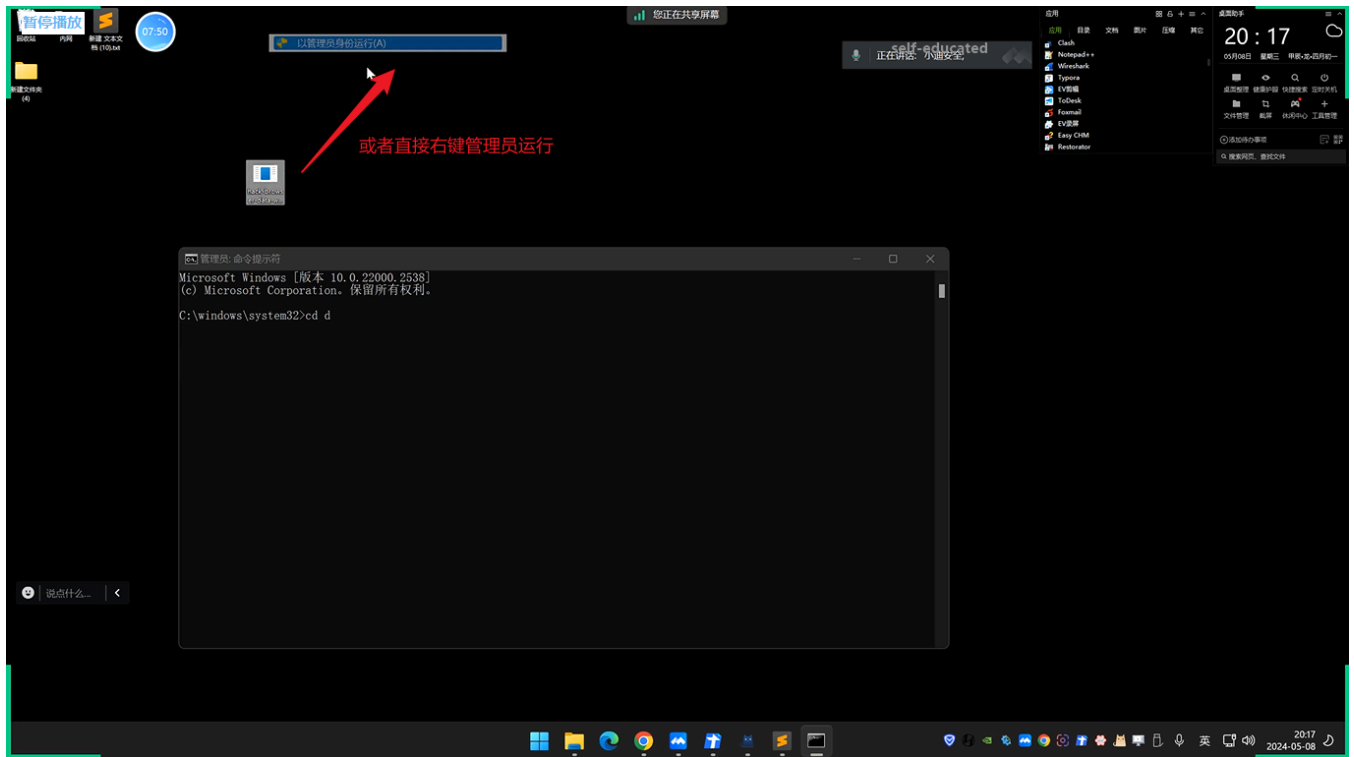
USAGE:
  [hack-browser-data -b chrome -f json -dir results --zip]
  Export all browsing data (passwords|cookies|history|bookmarks) from browser
  Github Link: https://github.com/moonD4rk/HackBrowserData

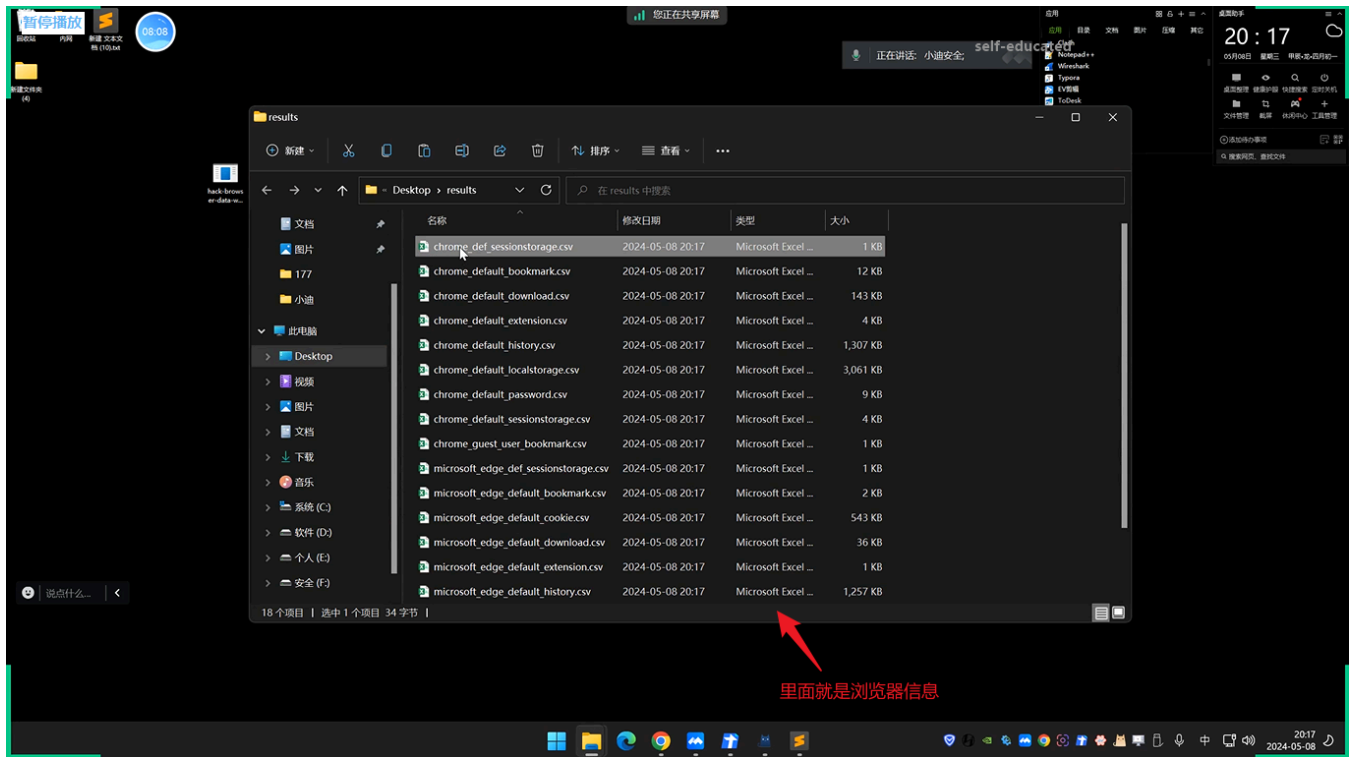
VERSION:
  0.4.5

GLOBAL OPTIONS:
  --verbose, -vv                verbose (default: false)
  --compress, --zip            compress result to zip (default: false)
  --browser value, -b value    available browsers: all|360|brave|chrome|chrome-beta|chromium|coccoc|dc|edge|firefox|opera|opera-gx|qq|sogou|vivaldi|yandex (default: "all")
  --results-dir value, --dir value export dir (default: "results")
  --format value, -f value     output format: csv|json (default: "csv")
  --profile-path value, -p value custom profile dir path, get with chrome://version
  --full-export, --full        is export full browsing data (default: true)
  --help, -h                  show help
  --version, -v               print the version

E:\工具\信息收集工具\hack-browser-data--快速获取浏览器的账户密码>
```

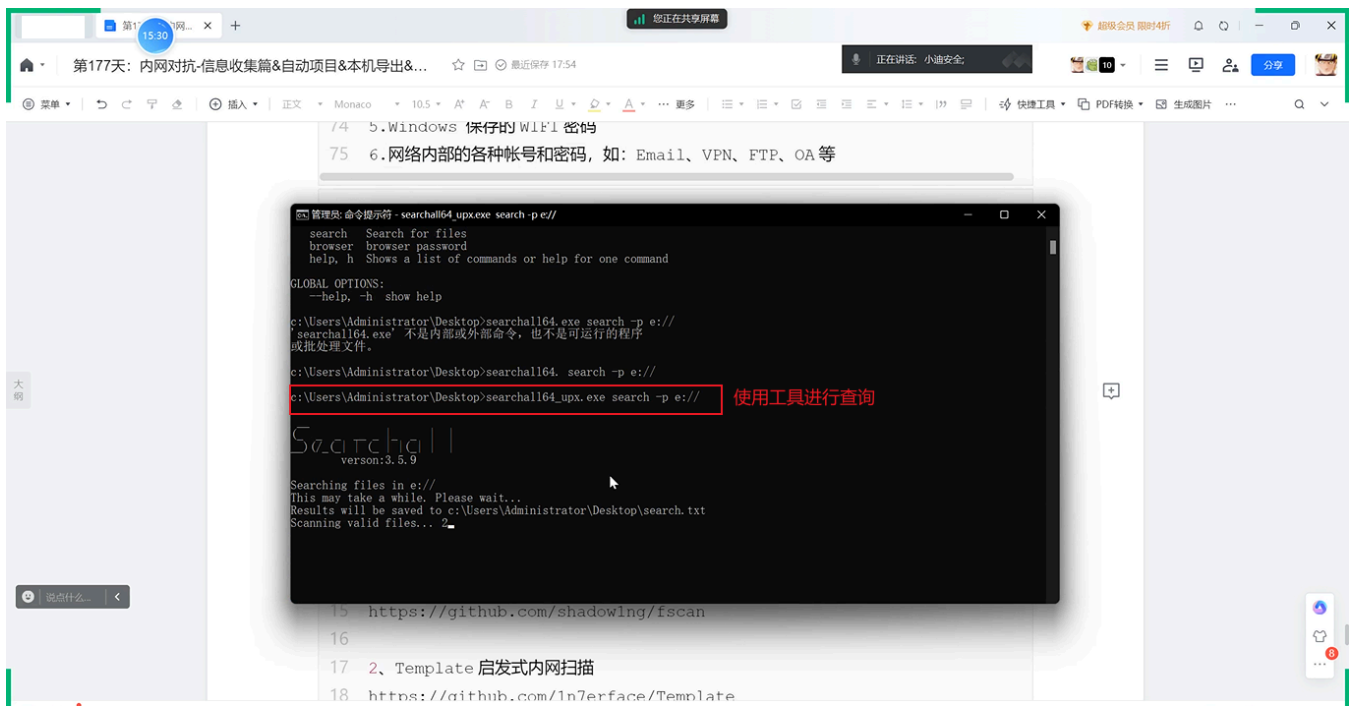
收集浏览器的账号密码

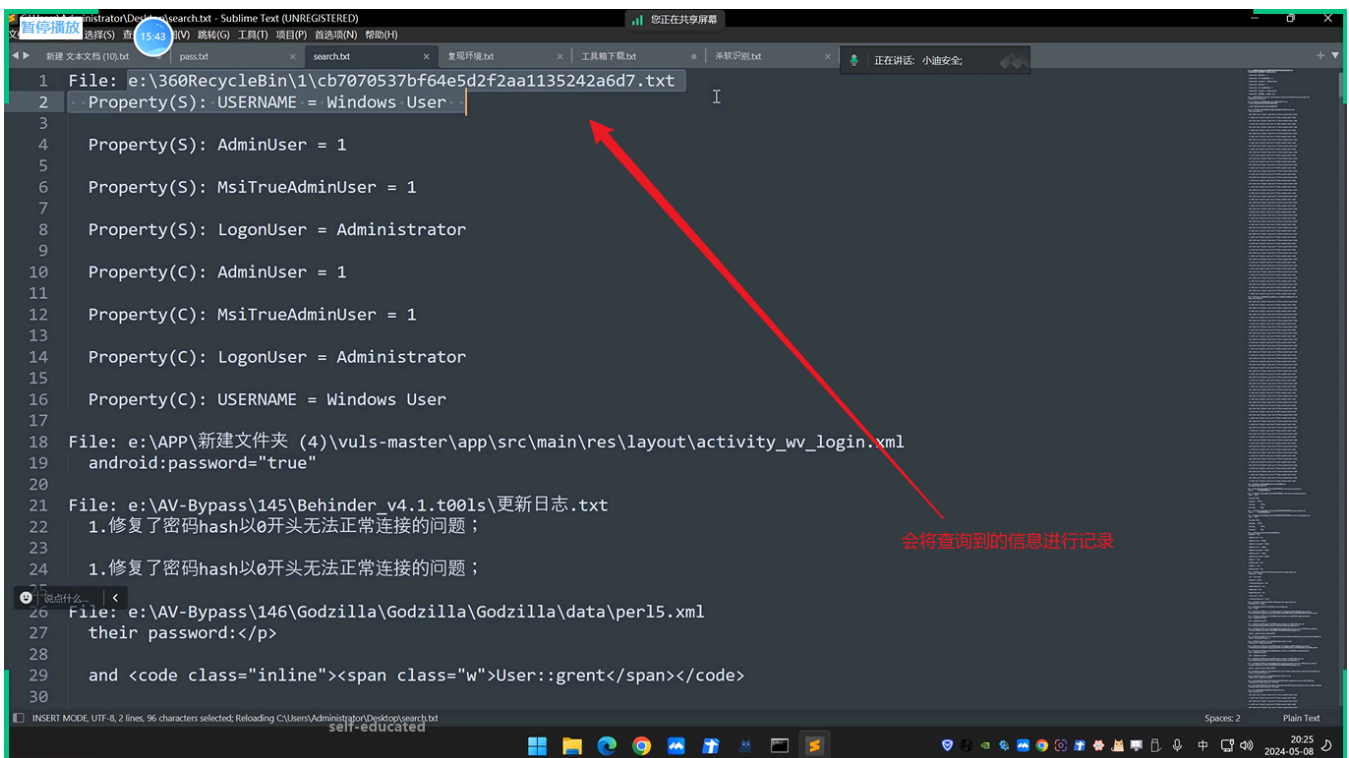
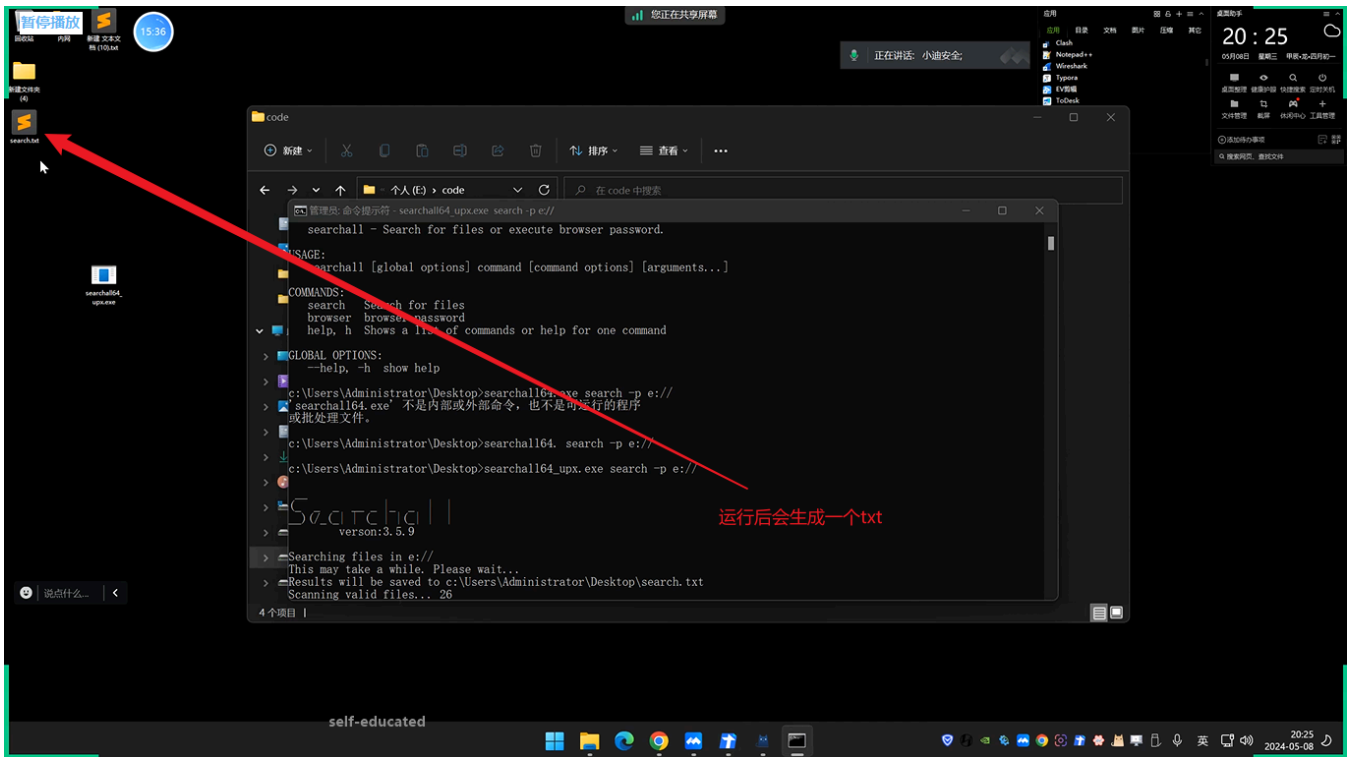


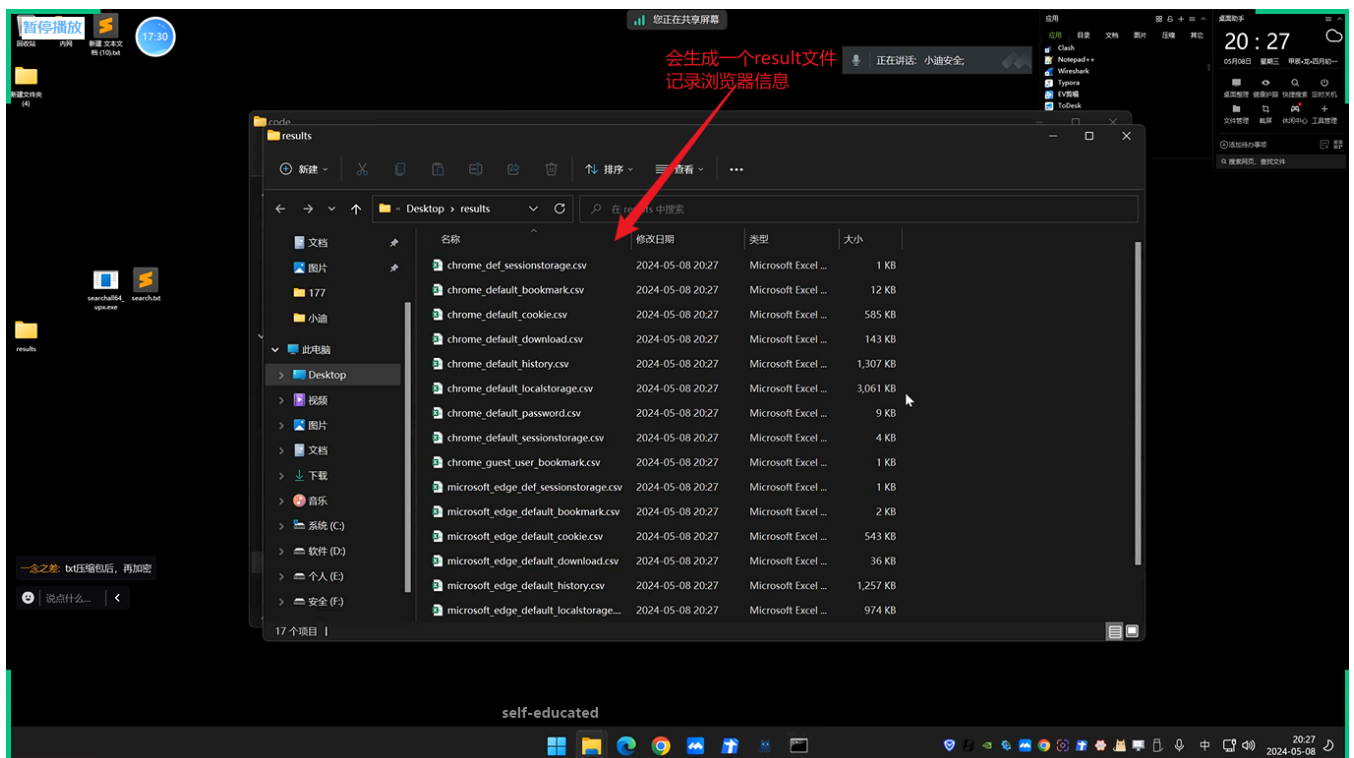
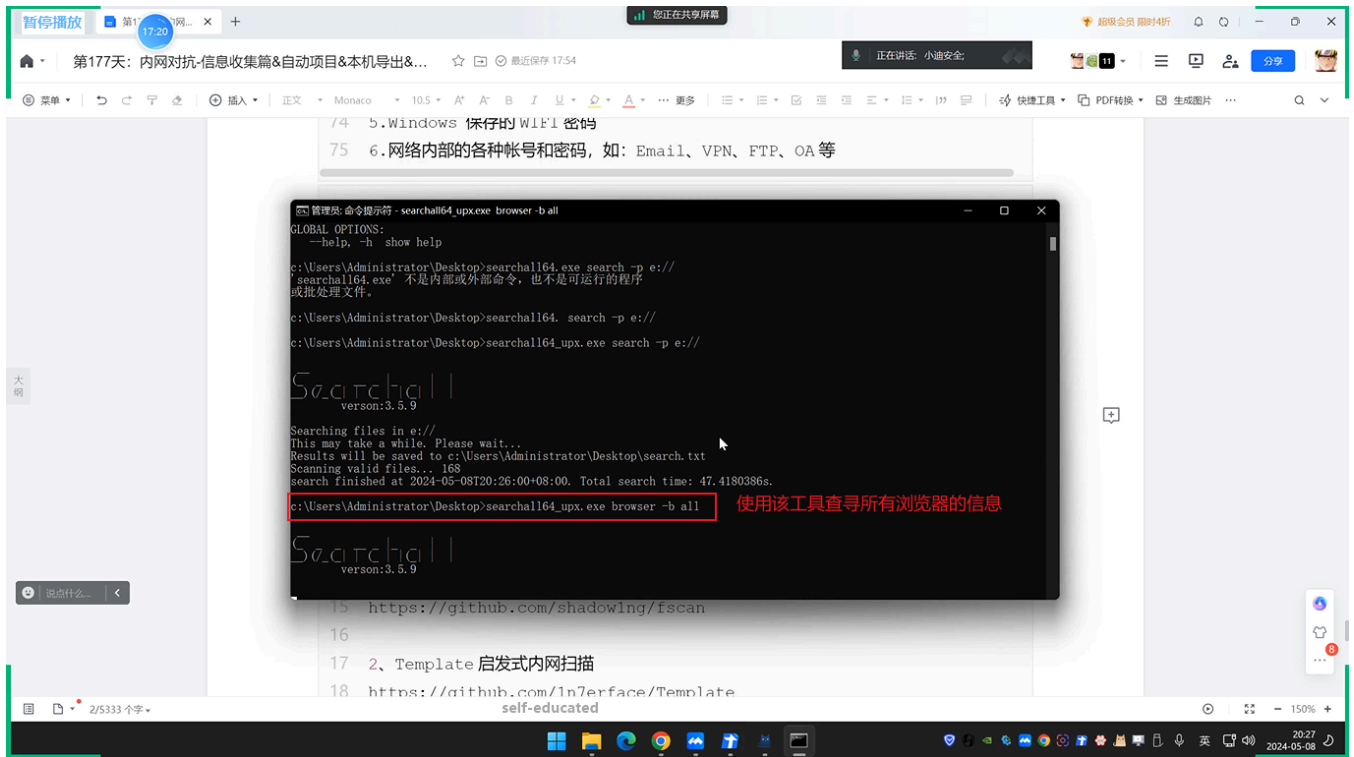


3.1.2 Searchall

- 2、Searchall 快速搜索服务器中的有关敏感信息还有浏览器的账户密码
- <https://github.com/Naturehi666/searchall>
- searchall64.exe search -p 指定路径
- searchall64.exe browser -b 指定的浏览器或者all

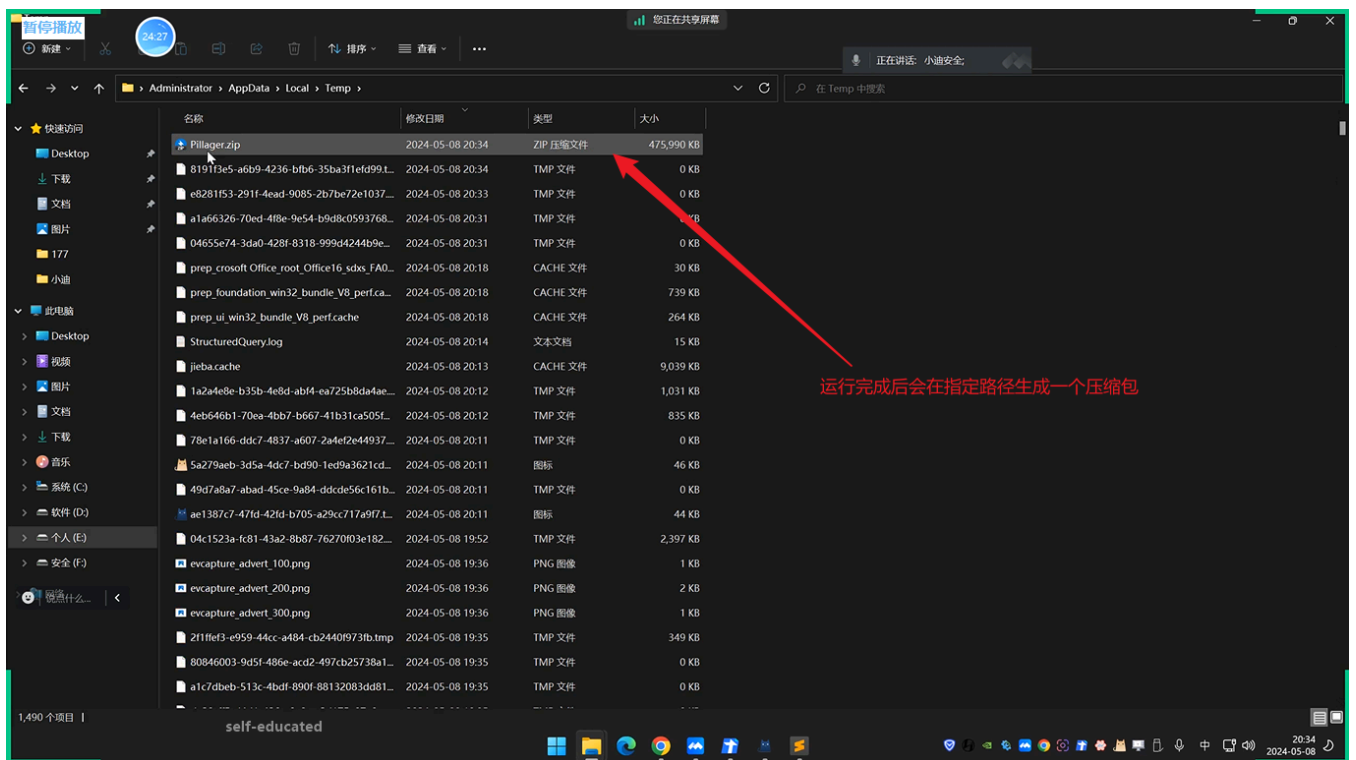
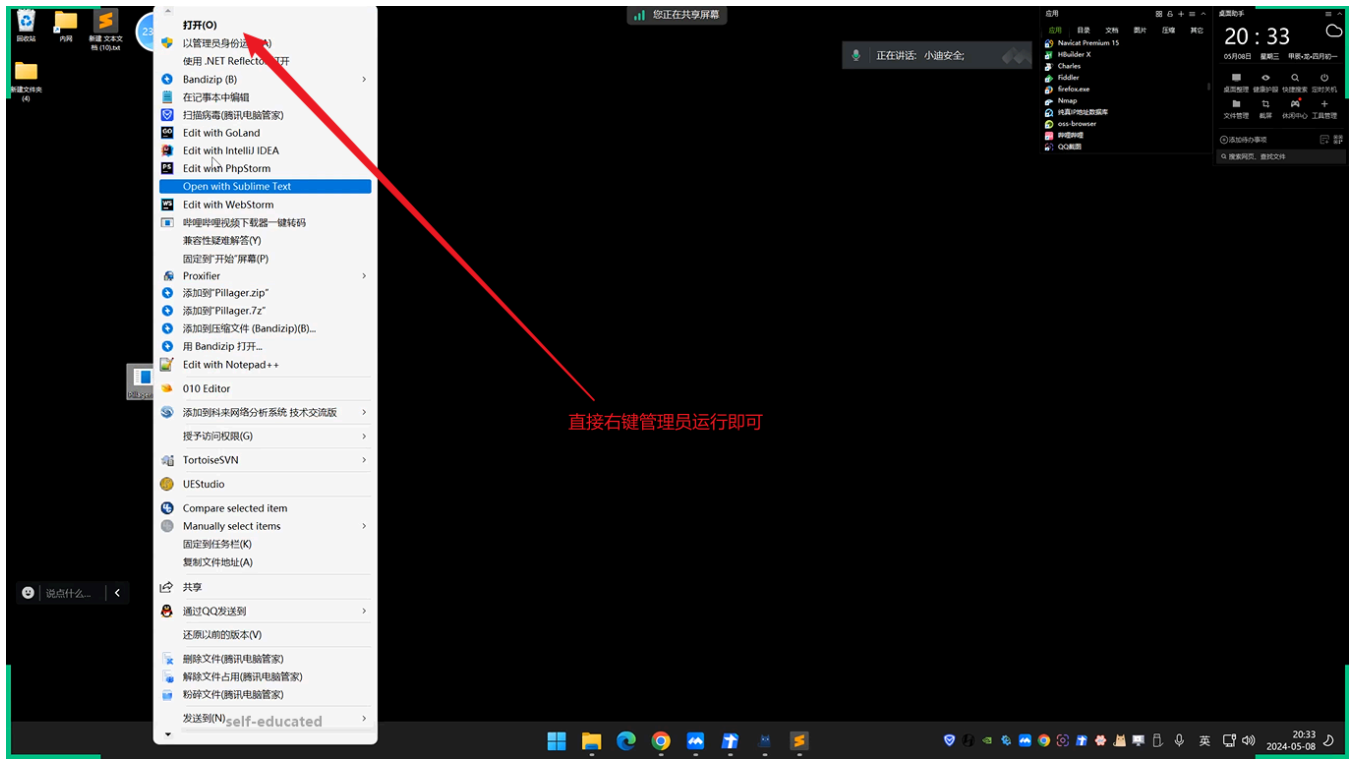


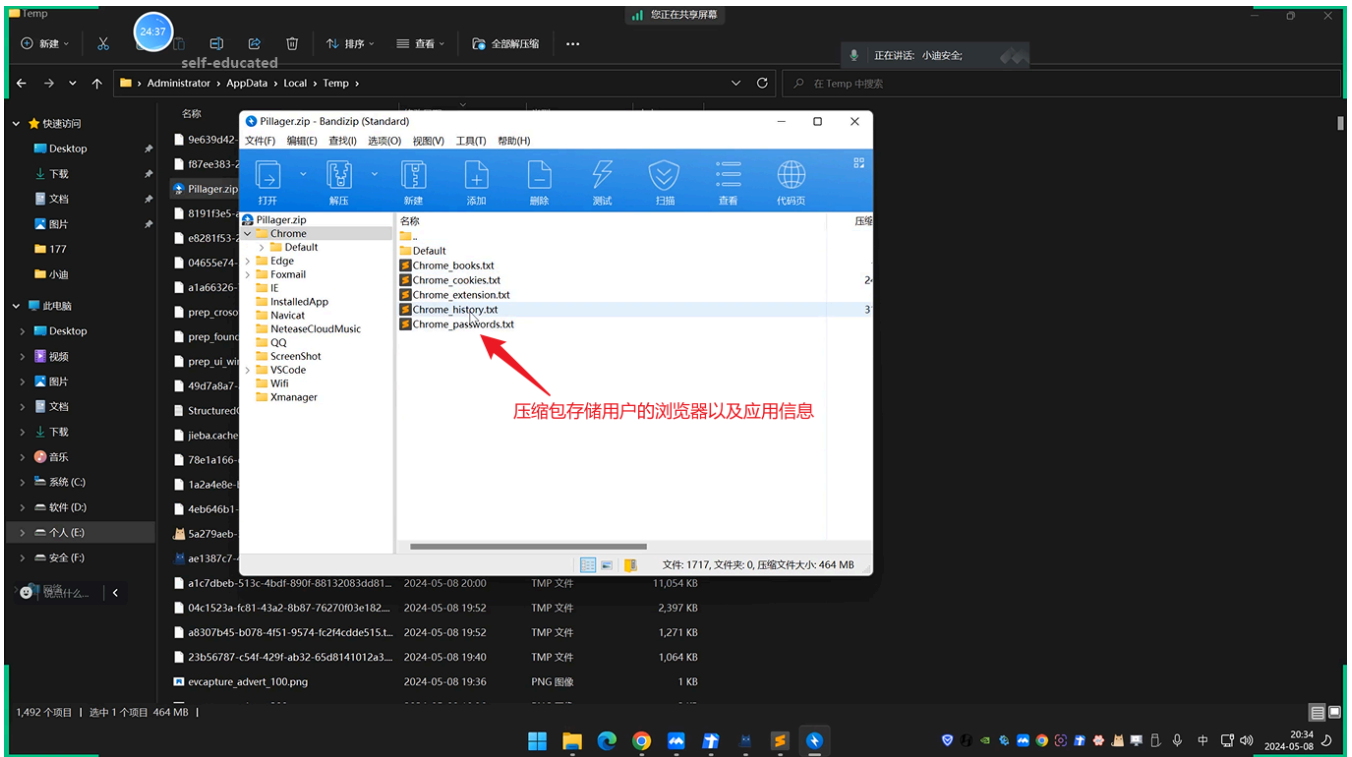




3.1.3 Pillager

3. Pillager 适用于后渗透期间的信息收集工具, 可以收集目标机器上敏感信息
- <https://github.com/qwqdanchun/Pillager>
- 文件生成路径: %Temp%\Pillager.zip

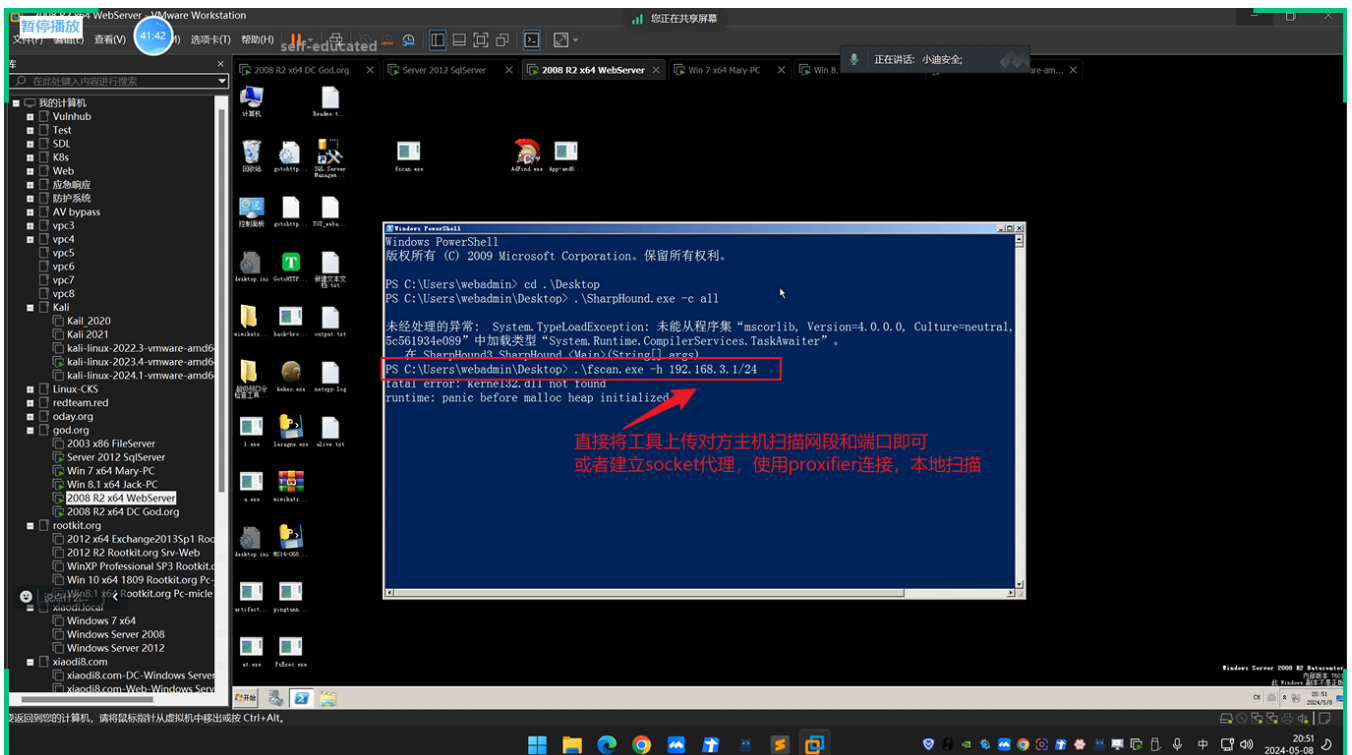




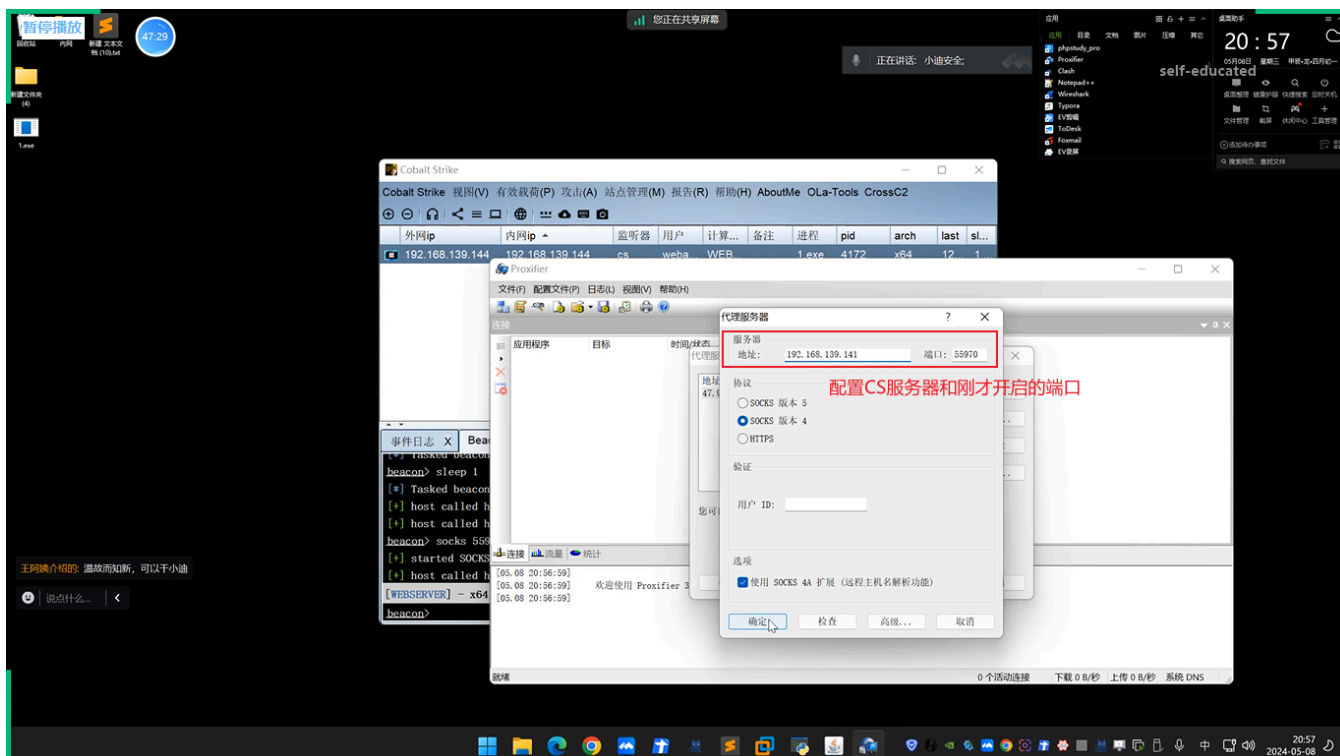
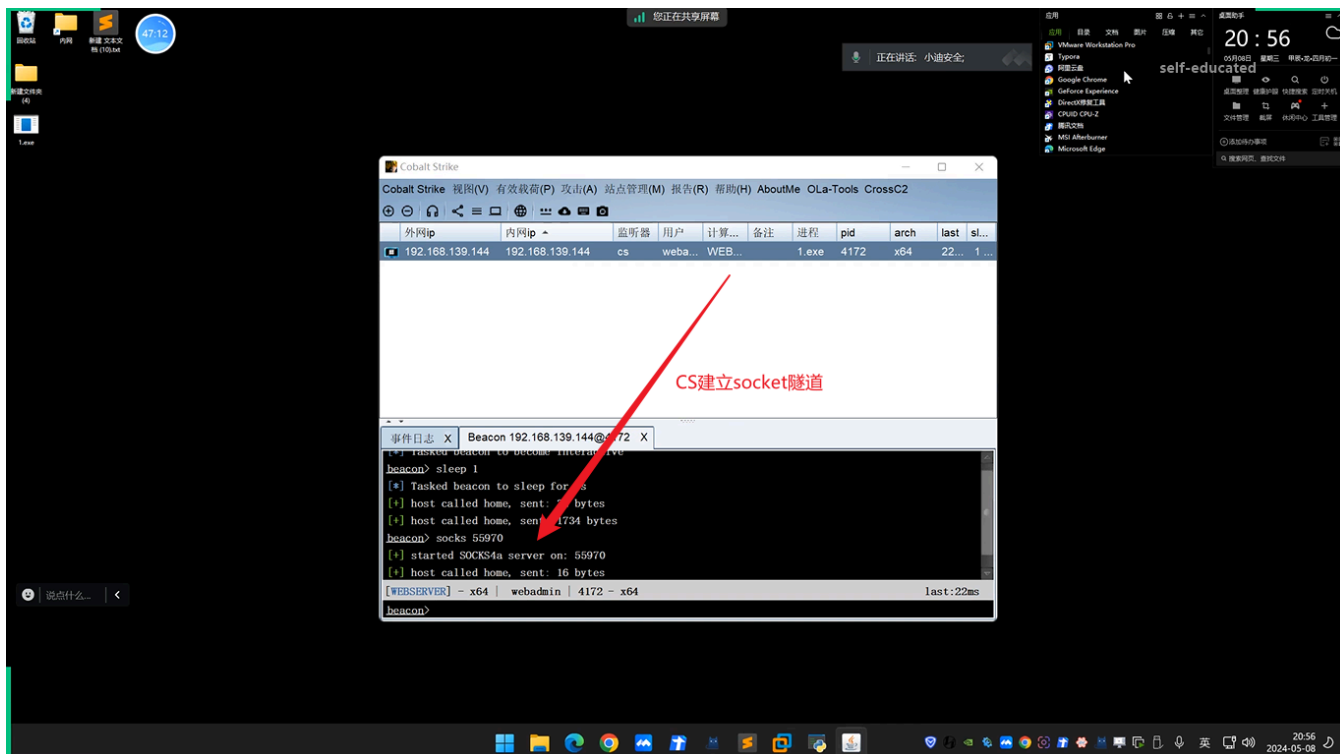
3.2 信息收集-工具项目-对外打点扫描类-FScan&Template

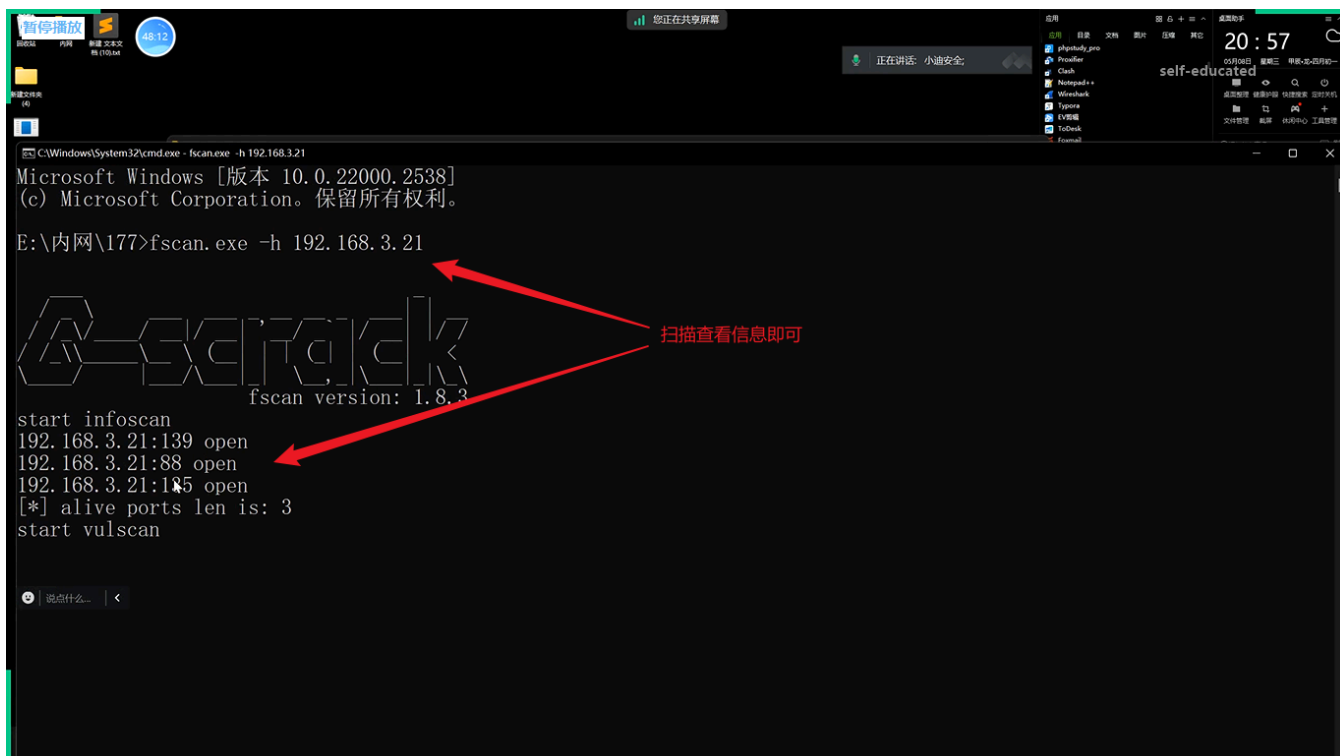
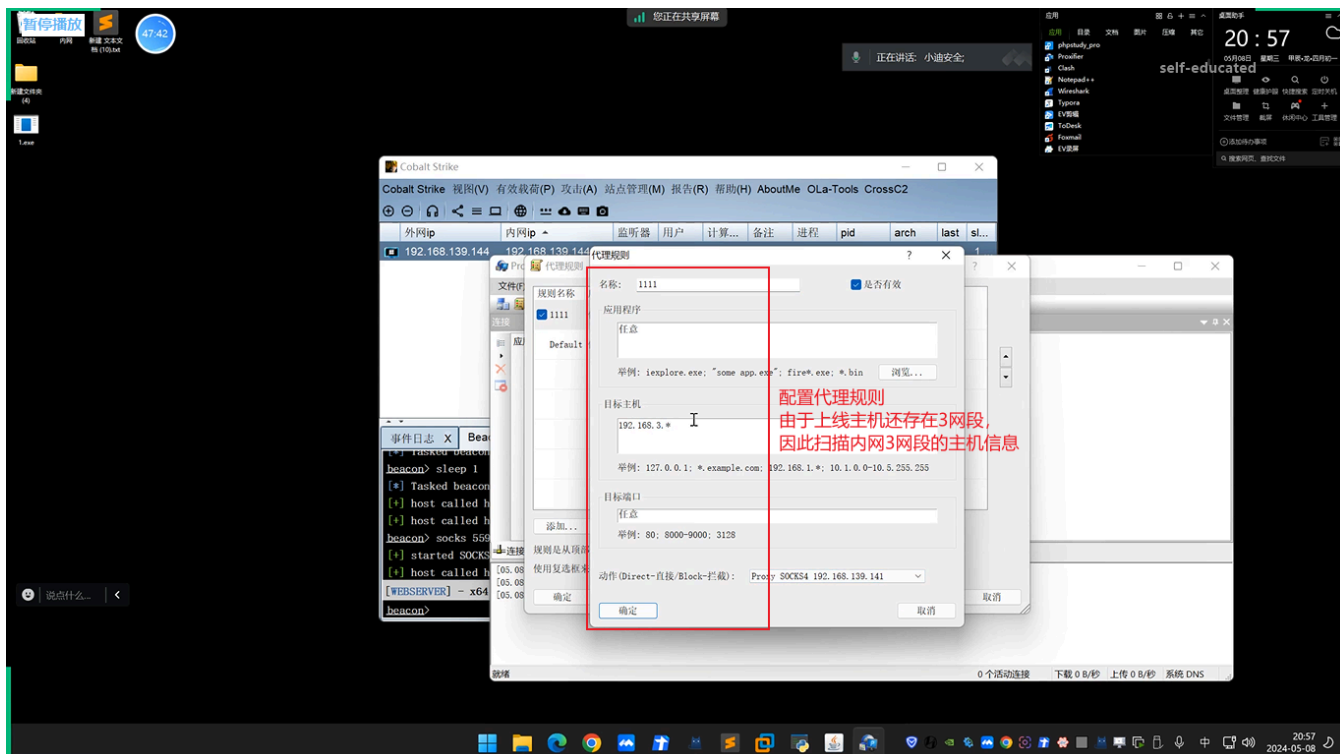
3.2.1 FScan

- 1、FScan内网综合扫描工具，方便一键自动化、全方位漏扫扫描。
- 2 <https://github.com/shadow1ng/fscan>



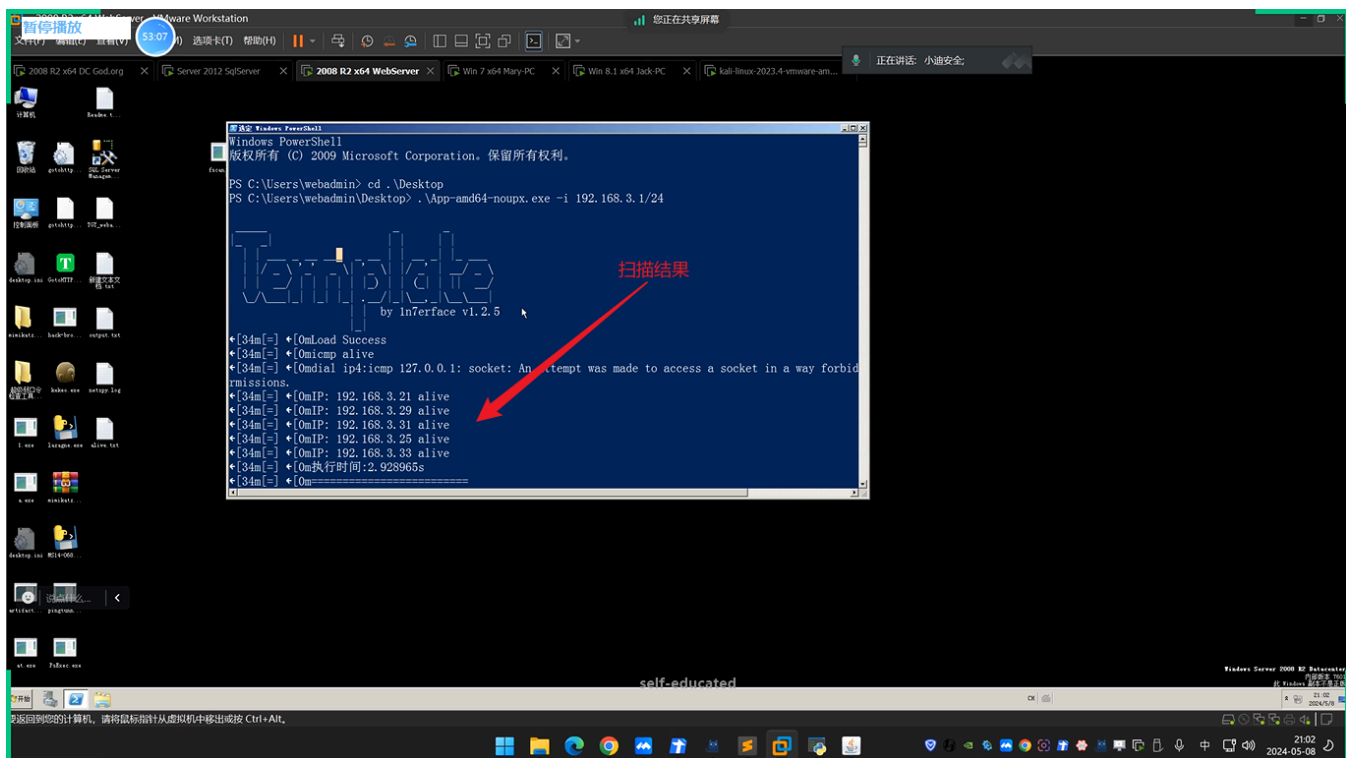
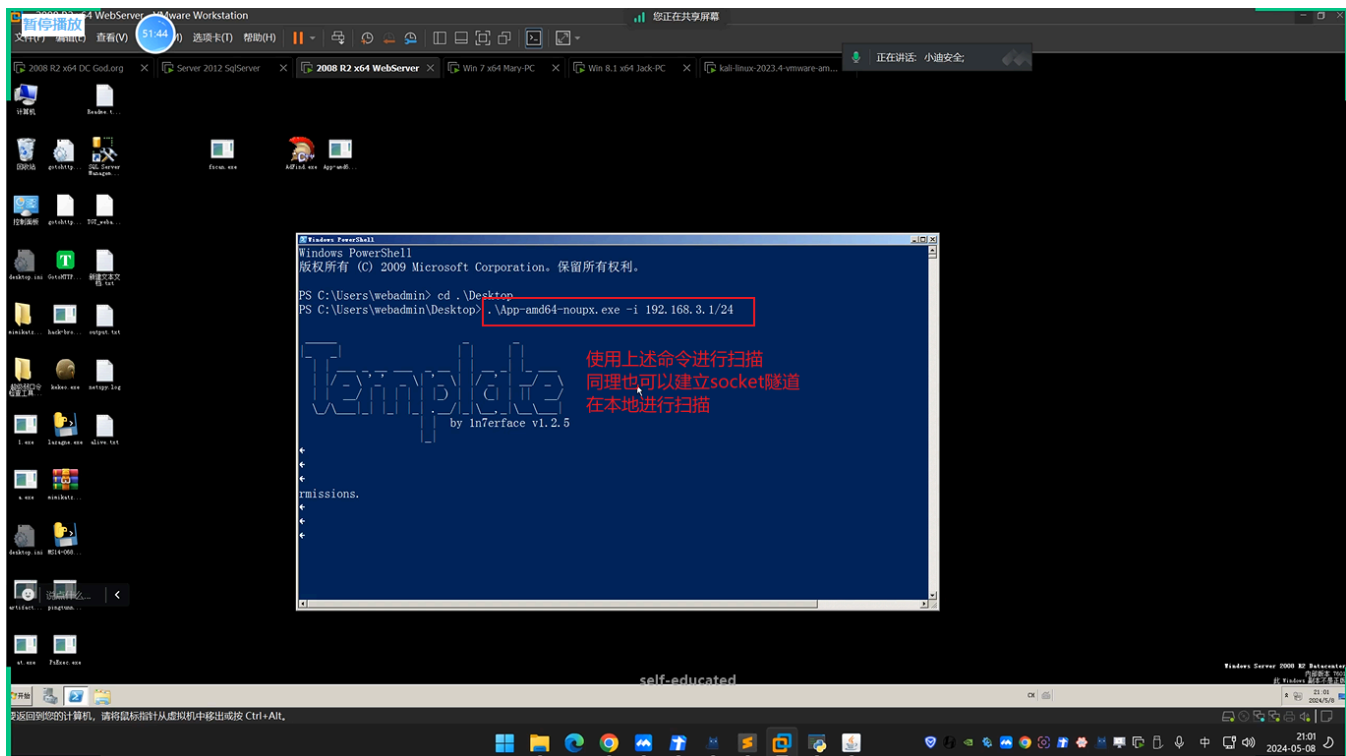
或者本地扫描:





3.2.2 Template

- 1 2、Template启发式内网扫描
- 2 <https://github.com/1n7erface/Template>

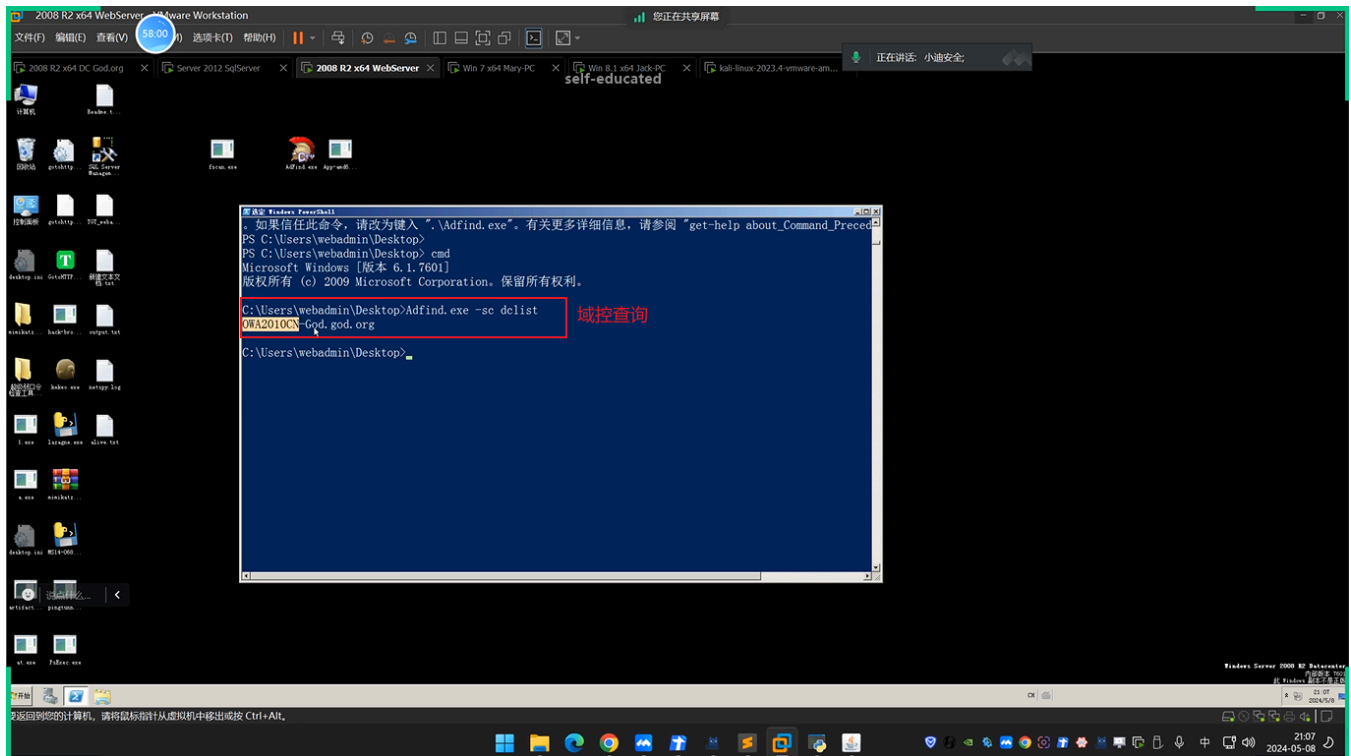


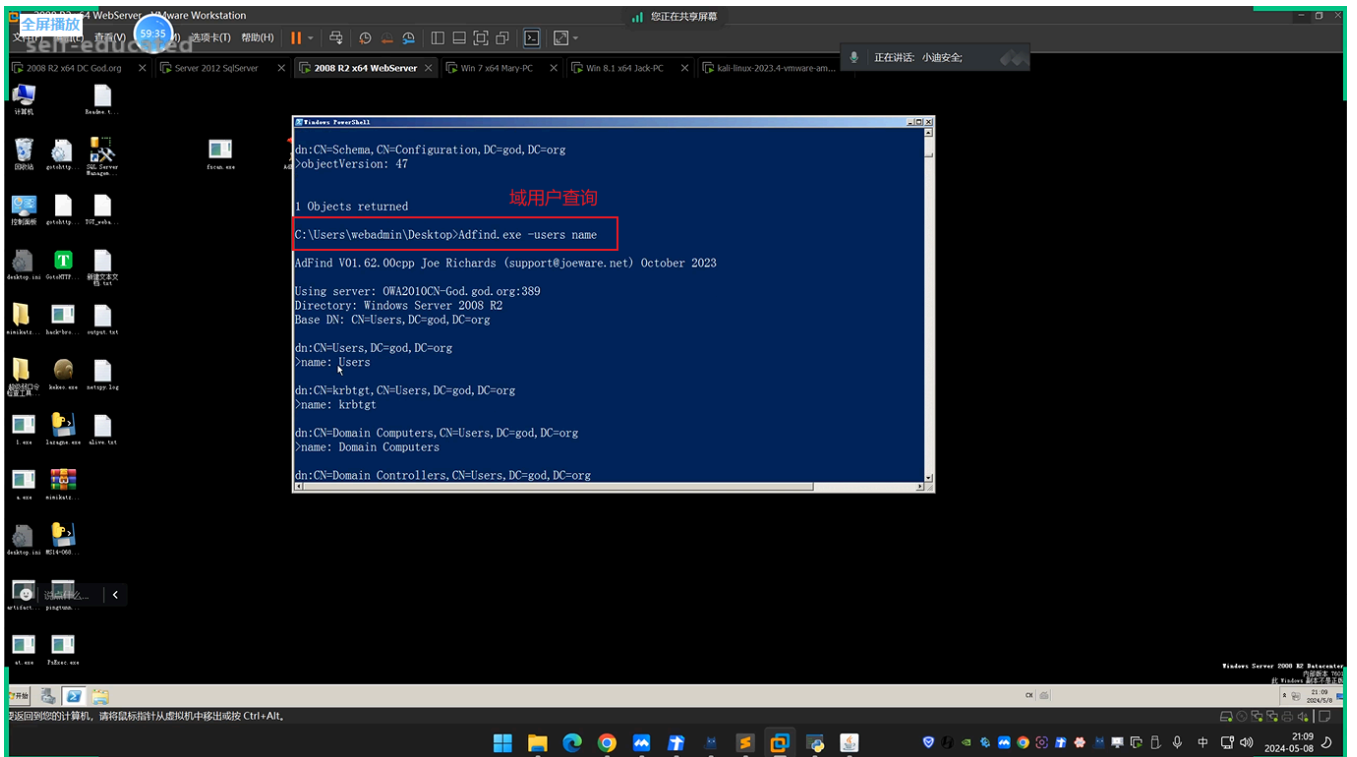
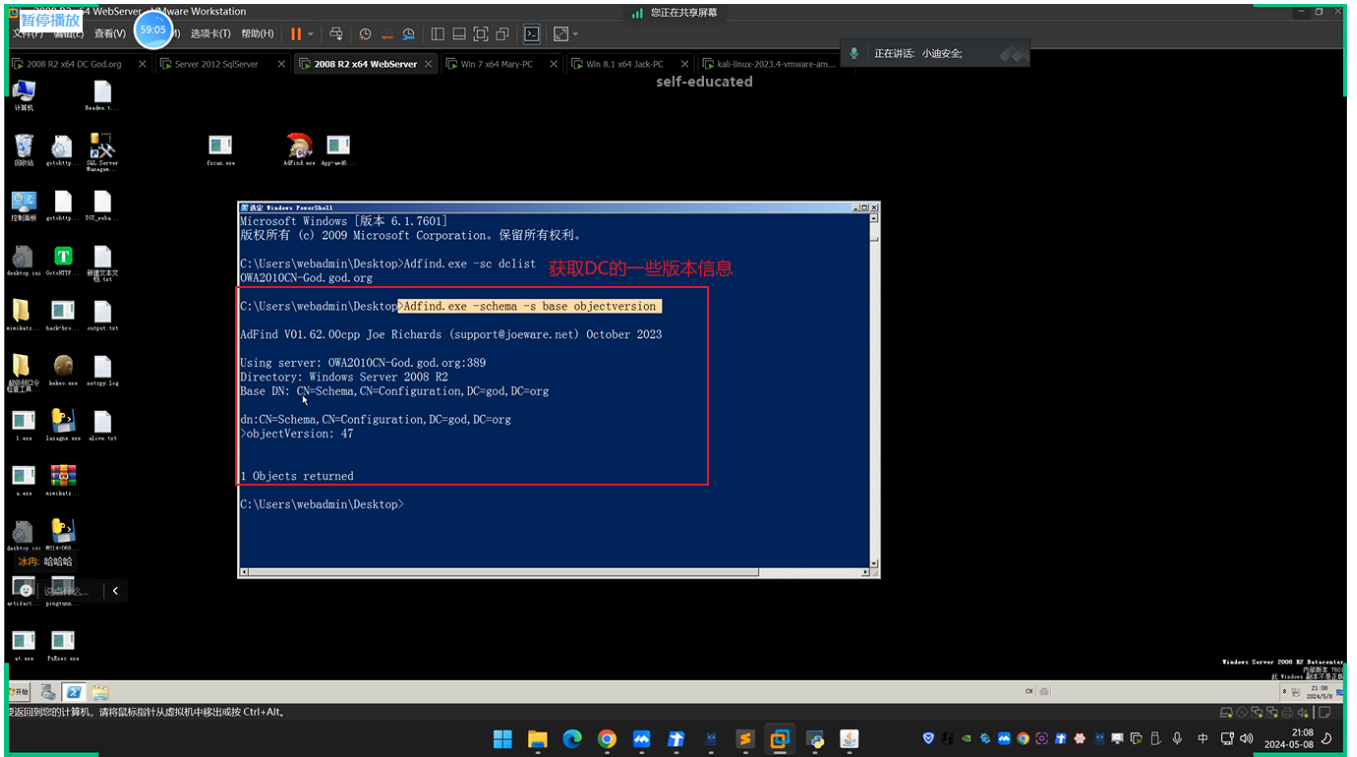
3.3 信息收集-工具项目-AD域环境分析类-Adfind&BloodHound

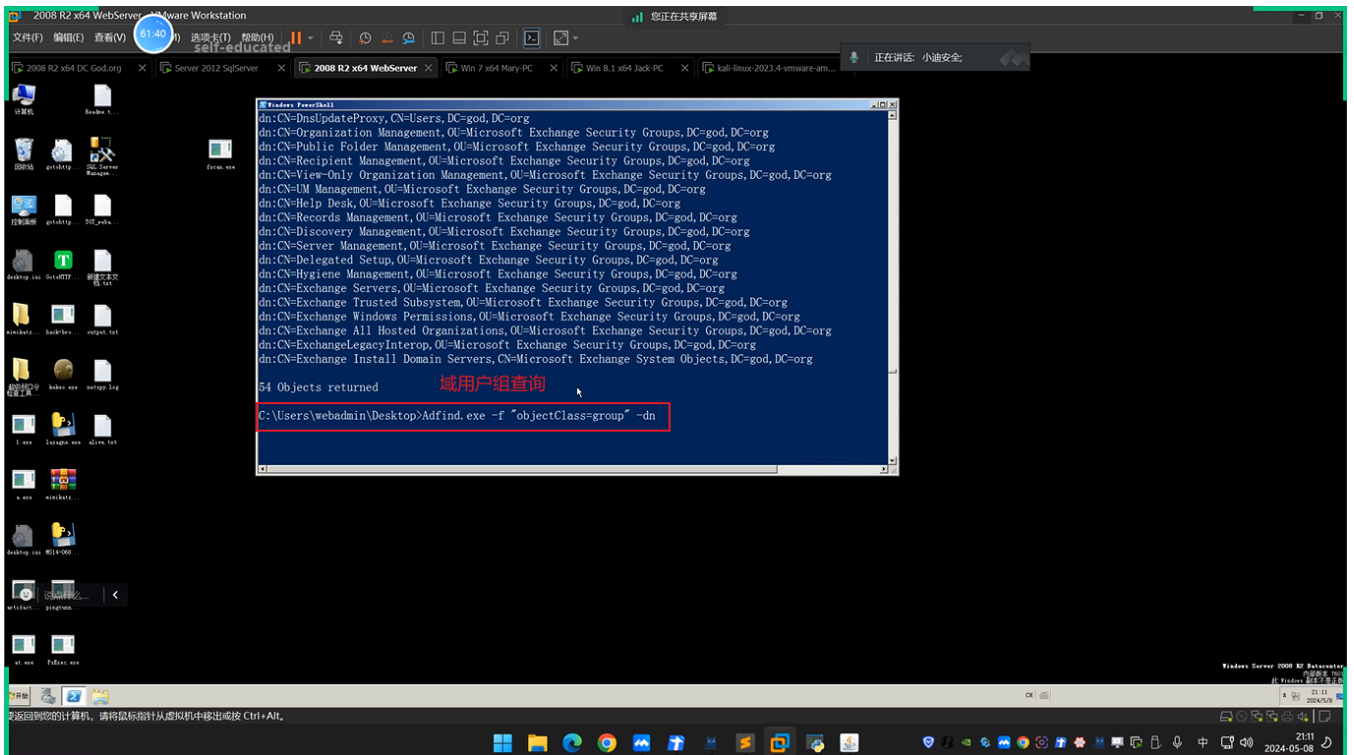
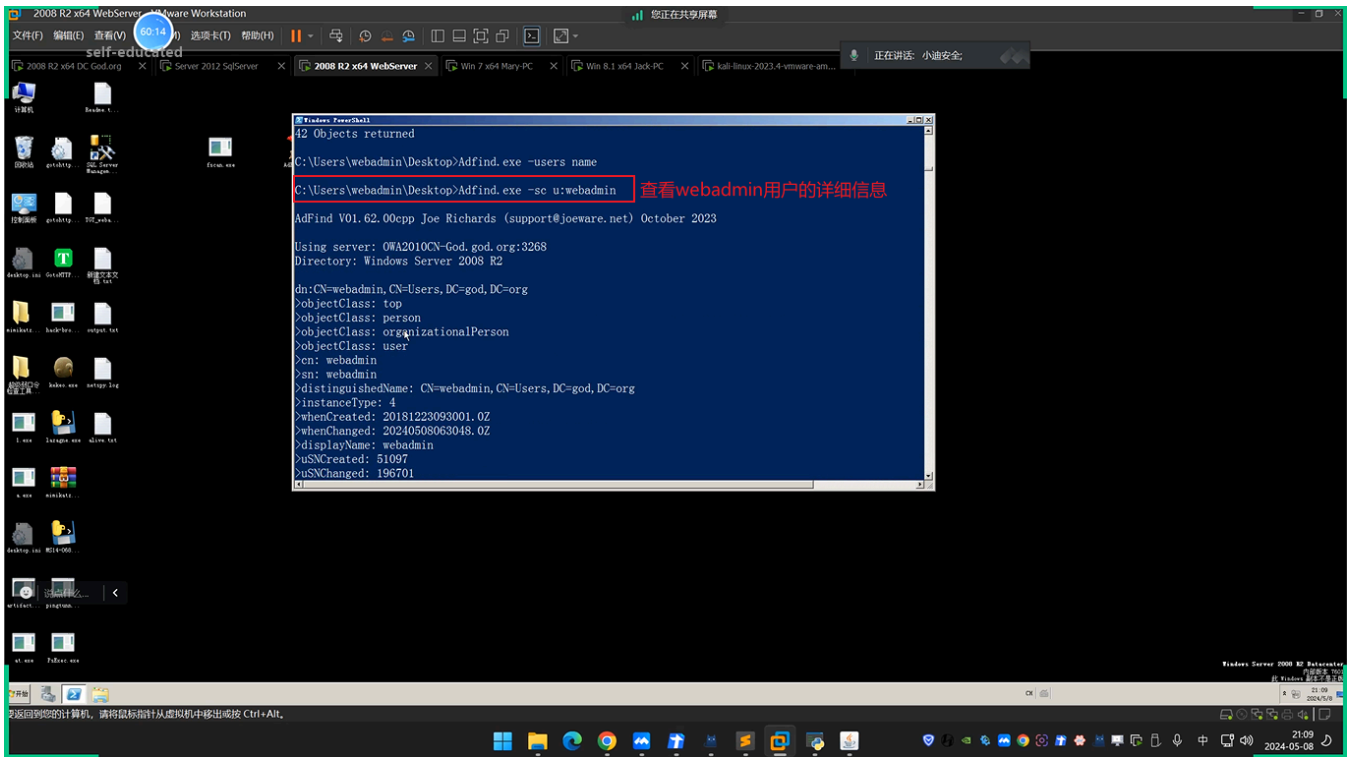
3.3.1 Adfind

1. Adfind 在域环境下非常强大的信息搜集工具
- <https://www.joeware.net/freetools/tools/adfind/>
- 域控查询:
- `Adfind.exe -sc dclist`
- `Adfind.exe -schema -s base objectversion`
- 域用户查询:

```
7 Adfind.exe -users name
8 Adfind.exe -sc u:webadmin
9 域用户组查询:
10 Adfind.exe -f "objectClass=group"
11 Adfind.exe -f "objectClass=group" -dn
12 查询域中计算机信息:
13 Adfind.exe -f "objectcategory=computer"
14 Adfind.exe -f "objectcategory=computer" dn
15 查询所有GPO:
16 Adfind.exe -sc gpodmp
17 查询域内委派:
18 https://mp.weixin.qq.com/s/WrUyPPBAIE-zmC3CfLYS7Q
```

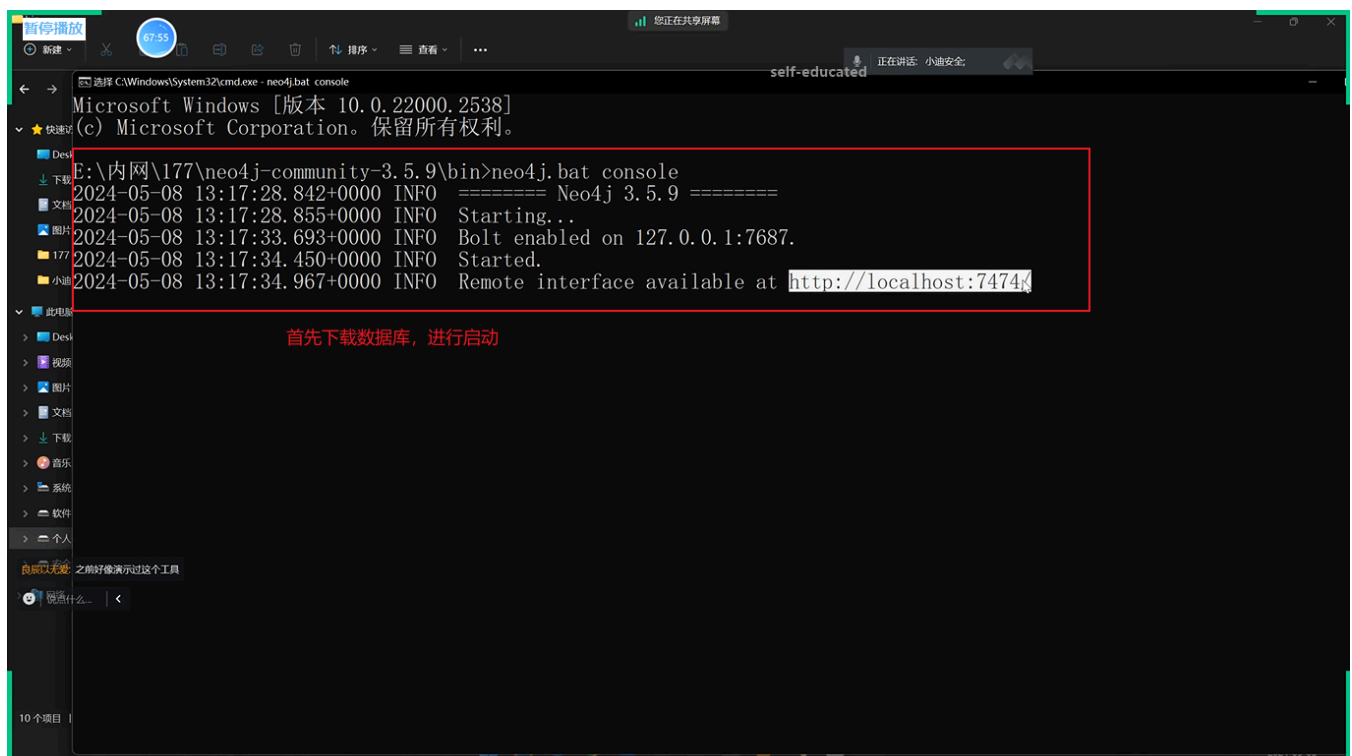






3.3.2 BloodHound

- 1 2、BloodHound 可视化图形分析域环境中的关系的工具
- 2 <https://github.com/BloodHoundAD/BloodHound>
- 3 -安装使用:
- 4 <https://cn-sec.com/archives/146548.html>
- 5 <https://mp.weixin.qq.com/s/cxfXKNhevXM6y31R7x53Sg>
- 6 -采集数据:
- 7 <https://github.com/BloodHoundAD/BloodHound/tree/master/Collectors>
- 8 <https://github.com/BloodHoundAD/BloodHound/tree/f4d9c1af1529124d33c9f360a27686eea51755e1/Collectors>
- 9 # 二进制采集工具命令:
- 10 SharpHound.exe -c all
- 11 # powershell采集工具命令:
- 12 powershell -exec bypass -command "Import-Module ./SharpHound.ps1; Invoke-BloodHound -c all"
- 13 -导入数据后分析



68:22

mp.weixin.qq.com/s/cx9XKNhevXM6y31R7x53Sg

正在讲话: 小迪安全self-educated

```
root@surge53:~# neo4j start
Directories in use:
home:       /usr/share/neo4j
config:     /usr/share/neo4j/conf
logs:       /usr/share/neo4j/logs
plugins:    /usr/share/neo4j/plugins
import:     /usr/share/neo4j/import
data:       /usr/share/neo4j/data
certificates: /usr/share/neo4j/certificates
licenses:  /usr/share/neo4j/licenses
run:        /usr/share/neo4j/run
Starting Neo4j.
Started neo4j (pid:2045). It is available at http://localhost:7474
There may be a short delay until the server is ready.
CSDN @我yesir
```

启动后，浏览器访问如下，默认账号密码都是neo4j。

Host: http://localhost:7474 Username: neo4j Password: neo4j

首次登录会提示修改密码，例如将密码修改为: 123456，修改后跳转如下页面，表示Neo4j安装成功。

使用默认账号密码登录

Neo4j

Getting started with Neo4j

Try Neo4j with live data

Cypher basics

Copyright © Neo4j, Inc. 2015-2022

Neo4j for a free Neo4j Cloud instance with neo4j Aura DB

BloodHound 安装

21:18 2024-05-08

68:39

正在讲话: 小迪安全self-educated

21:18 05月08日 星期三 早晨6:40开始的一

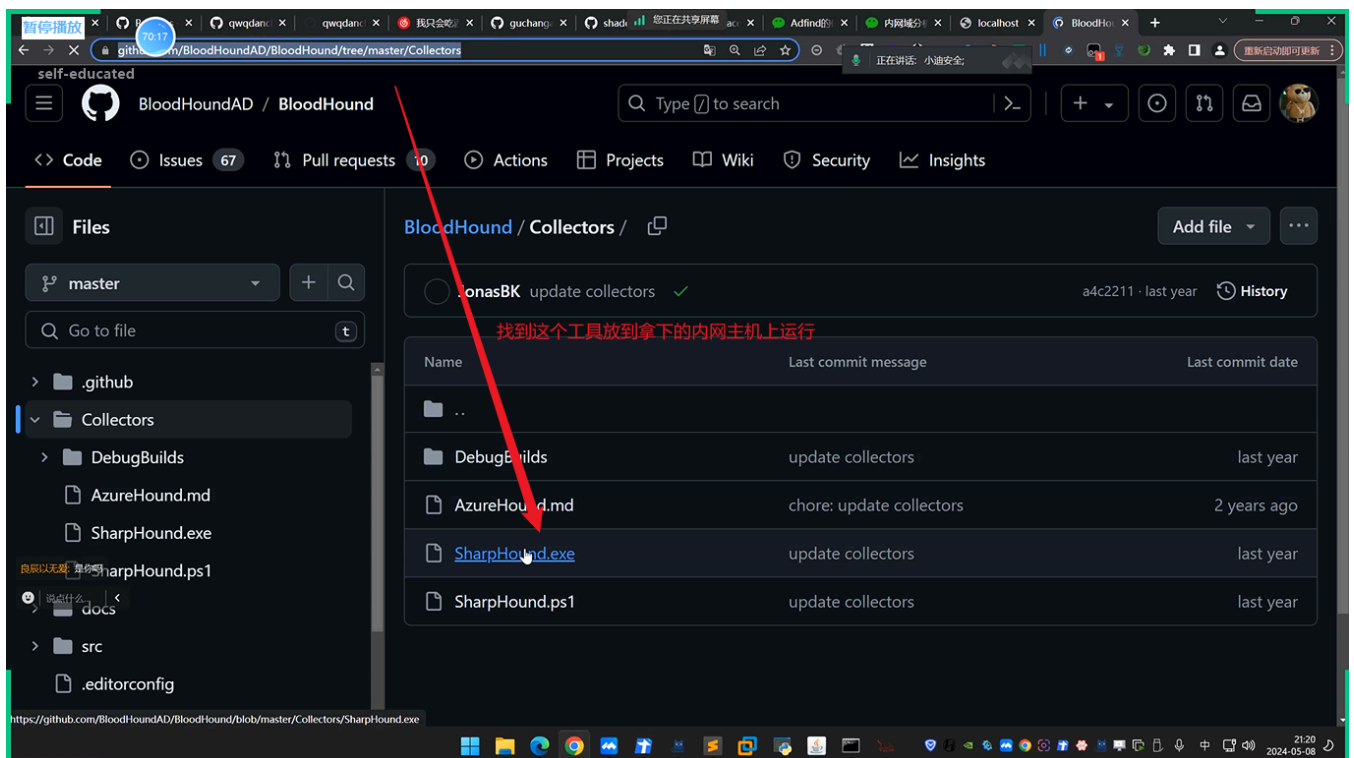
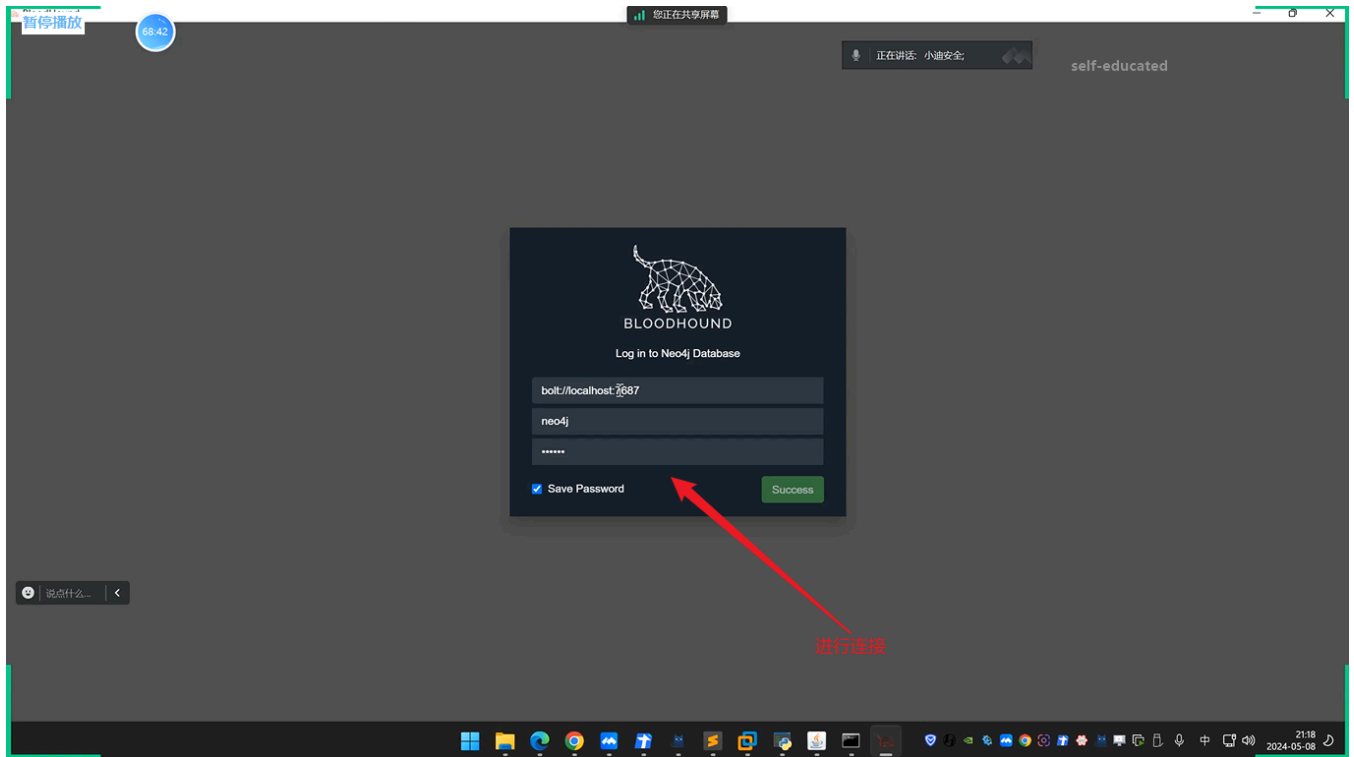
然后启动blood的exe程序

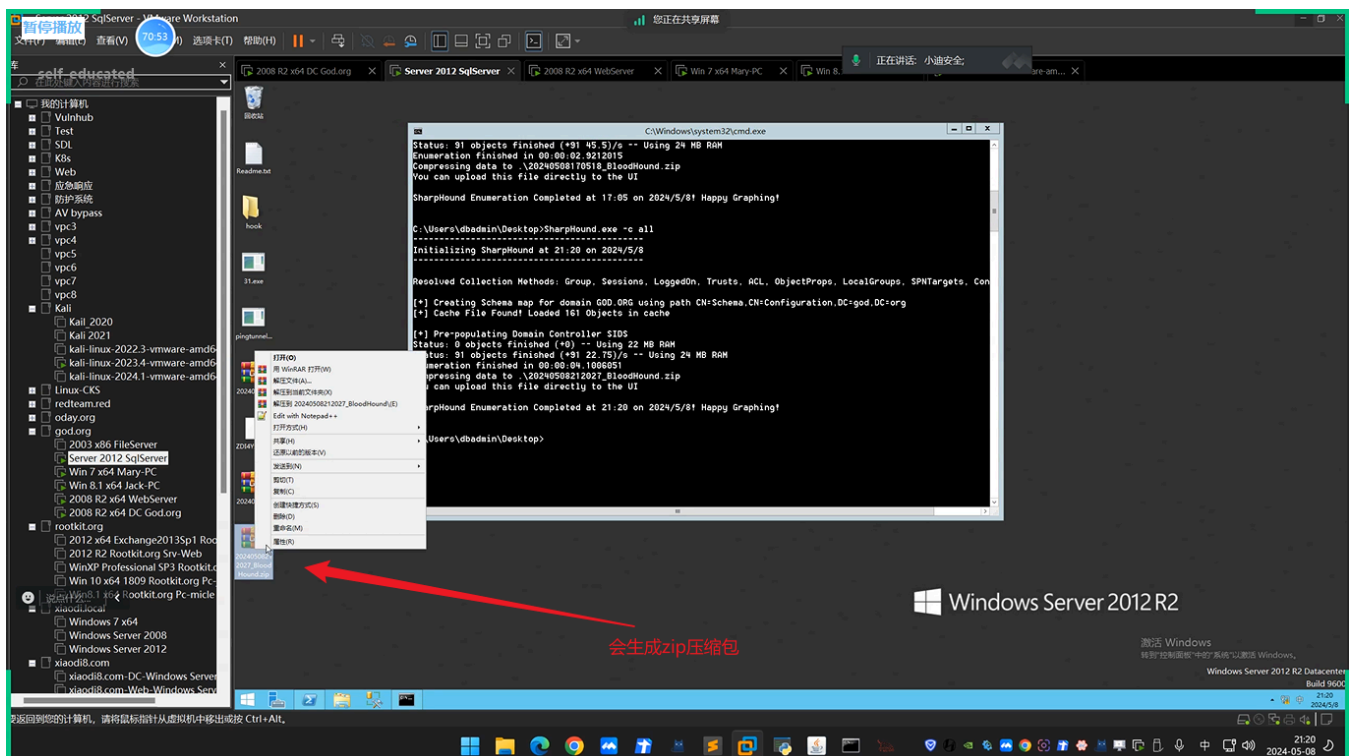
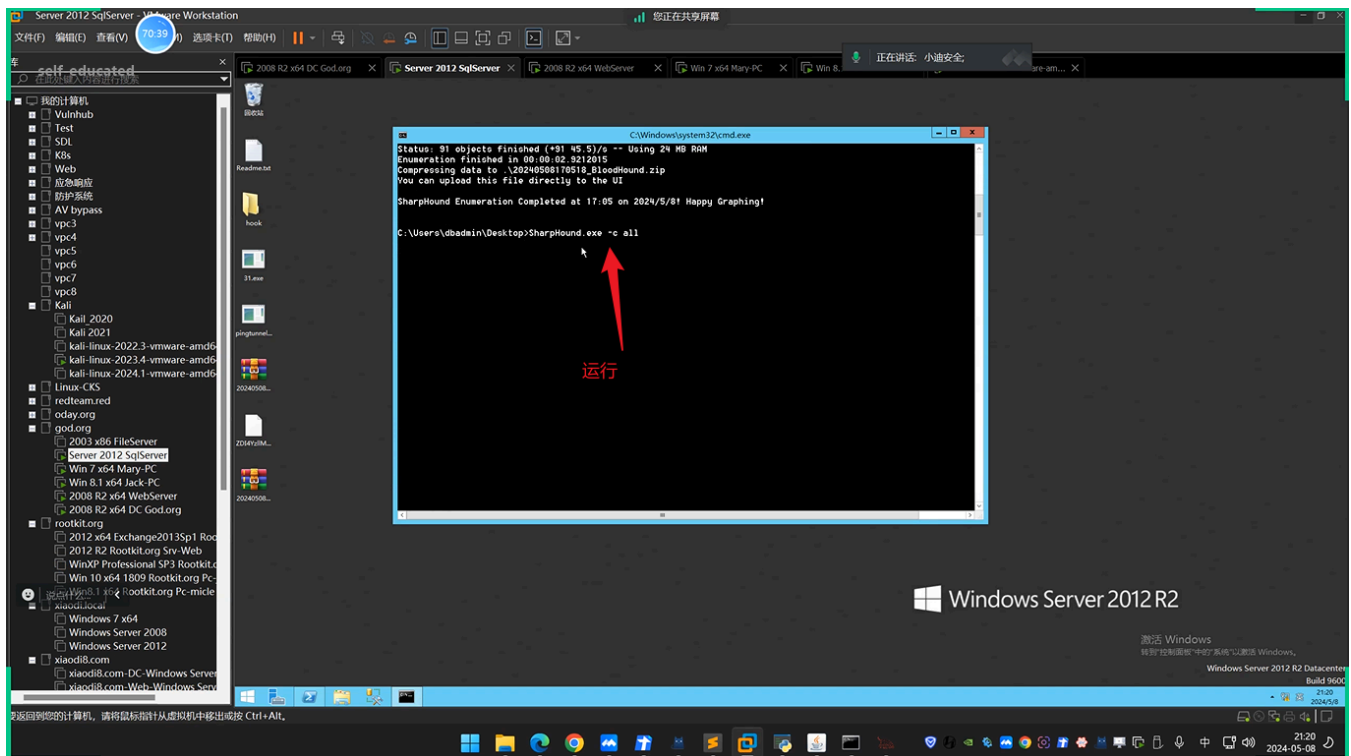
BloodHound-win32-x64

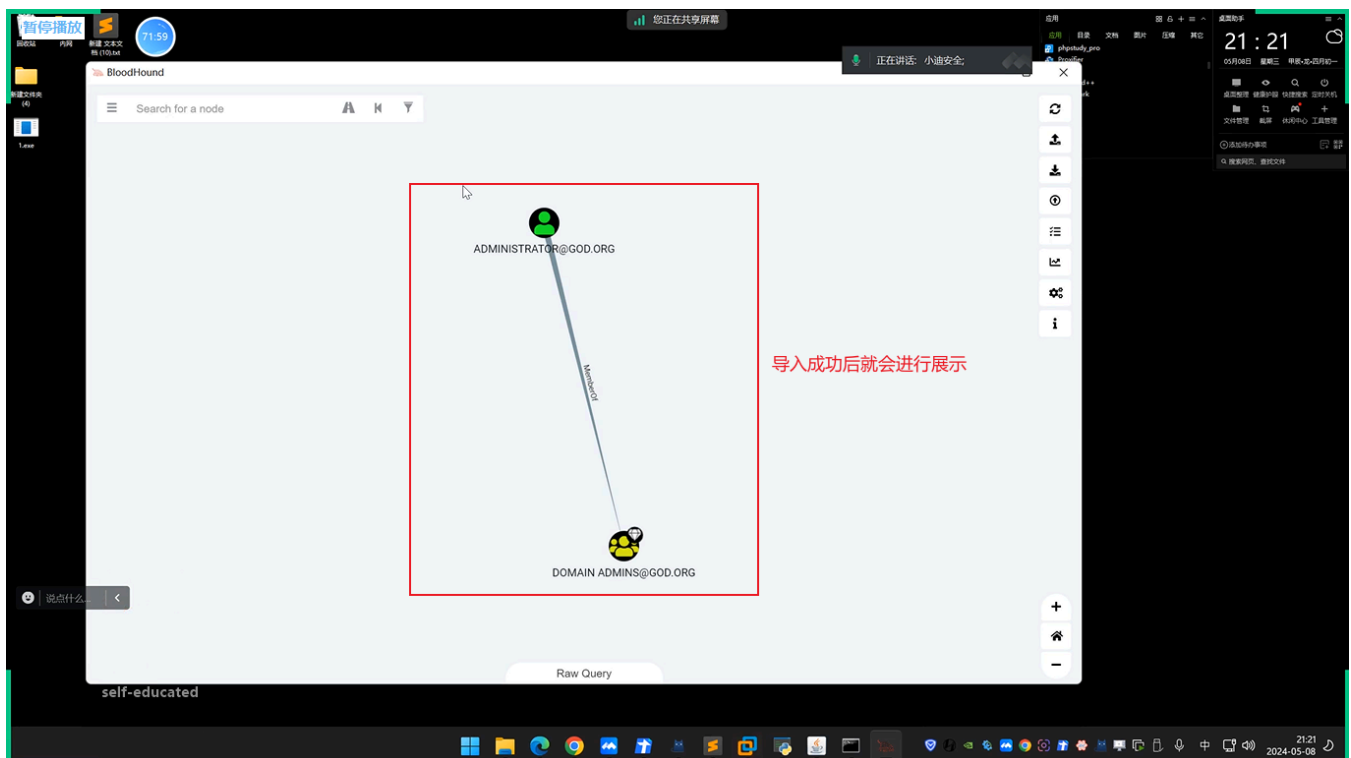
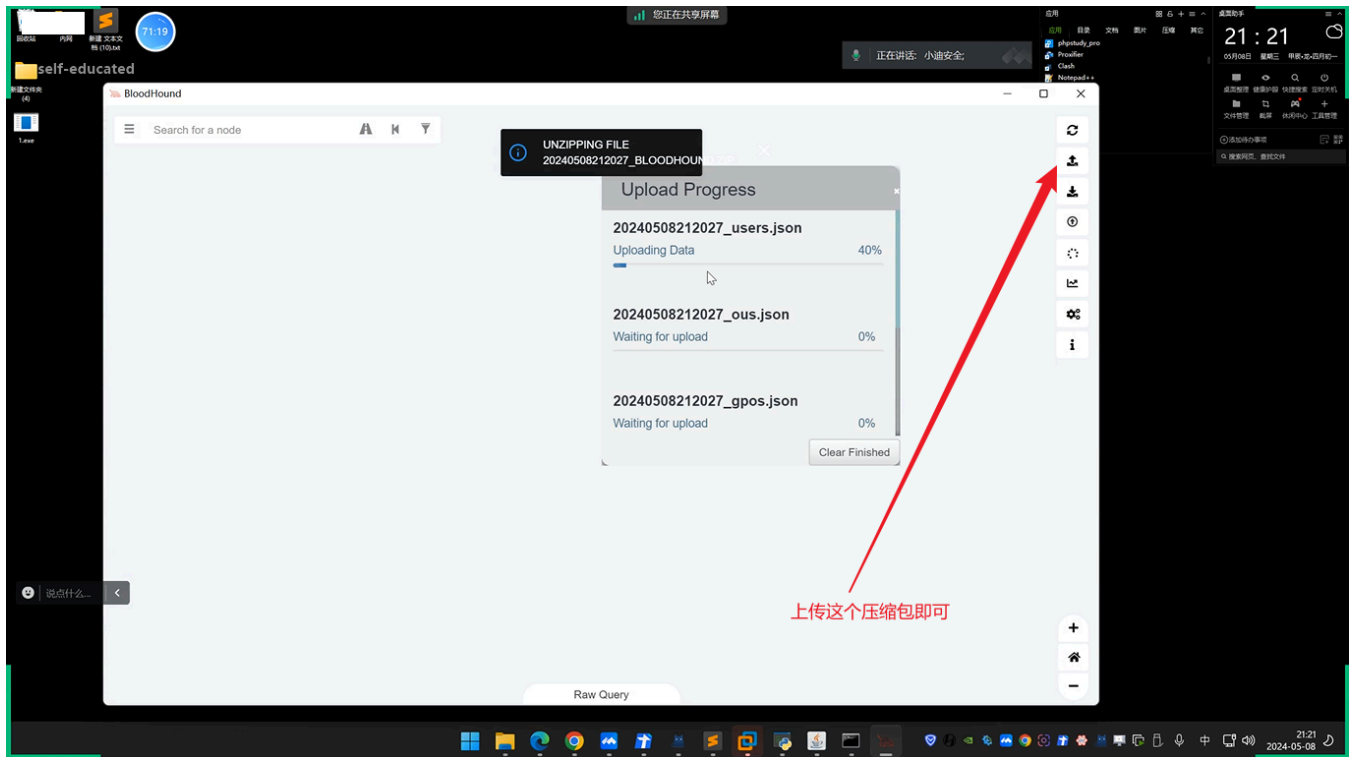
名称	修改日期	类型	大小
locales	2021-07-16 2:14	文件夹	
resources	2021-07-16 2:14	文件夹	
swiftshader	2021-07-16 2:14	文件夹	
BloodHound.exe	2021-07-16 2:14	应用程序	106,487 KB
chrome_100_percent.pak	2021-07-16 2:14	PAK 文件	176 KB
chrome_200_percent.pak	2021-07-16 2:14	PAK 文件	313 KB
d3dcompiler_47.dll	2021-07-16 2:14	应用程序扩展	4,377,409
ffmpeg.dll	2021-07-16 2:14	应用程序扩展	2,708 KB
icudtl.dat	2021-07-16 2:14	StellarPlayer.exe...	10,260 KB
libEGL.dll	2021-07-16 2:14	应用程序扩展	371 KB
libGLESv2.dll	2021-07-16 2:14	应用程序扩展	7,679 KB
LICENSE	2021-07-16 2:14	文件	2 KB
LICENSES.chromium.html	2021-07-16 2:14	HTML 文件	4,754 KB
resources.pak	2021-07-16 2:14	PAK 文件	4,691 KB
snapshot_blob.bin	2021-07-16 2:14	BIN 压缩文件	50 KB

20个项目 | 选中1个项目 105 MB

21:18 2024-05-08







后续参考上述链接的使用规则即可。

资源:

- 1 #其他:
- 2 <https://github.com/guchangan1/All-Defense-Tool>
#E58685E7BD91E694B6E99B86E5B7A5E585B7